
개인정보 영향평가 수행 안내서

2020. 12.



개인정보보호위원회



한국인터넷진흥원

「개인정보 보호법」에 따른

개인정보 영향평가 수행 안내서

(개정판)

버 전 : 5.0

개정일자 : 2020. 12.

목 차

제1장 총론

제1절 개인정보 영향평가 개요	6
1. 개념	
2. 목적 및 필요성	
3. 평가 대상	
4. 평가 시기	
5. 평가 수행 주체	
6. 평가 수행 체계	
제2절 용어정의 및 추진근거	10
1. 용어정의	
2. 추진근거	
제3절 개인정보 영향평가 수행절차 요약	13

제2장 영향평가 수행절차

제1절 영향평가 사전준비 단계	16
1. 사업계획의 작성	
1.1. 영향평가 필요성 검토	
1.2. 사전평가 수행	
1.3. 사업계획서 작성	
2. 영향평가 기관 선정	
2.1. 제안요청서 작성 및 사업발주	
2.2. 영향평가 기관 선정	
제2절 영향평가 수행단계	22
1. 영향평가 수행계획 수립	
1.1. 영향평가 수행계획 수립	
1.2. 영향평가팀 구성방안 협의	
1.3. 영향평가팀 역할 정의	
1.4. 영향평가팀 운영계획 수립	
2. 평가자료 수집	
2.1. 내부 정책자료 분석	
2.2. 외부 정책자료 분석	
2.3. 대상시스템 관련 자료 분석	

3. 개인정보 흐름 분석
 - 3.1. 개인정보 처리 업무 현황 분석
 - 3.2. 개인정보 처리 업무 흐름도 작성
 - 3.3. 개인정보 흐름표 작성
 - 3.4. 개인정보 흐름도 작성
 - 3.5. 정보시스템 구조도 및 정보보호 시스템 목록 작성
4. 개인정보 침해요인 분석
 - 4.1. 평가항목 구성
 - 4.2. 개인정보 보호조치 현황파악
 - 4.3. 개인정보 침해요인 도출
 - 4.4. 개인정보 위험도 산정
5. 개선계획 수립
 - 5.1. 개선사항 도출
 - 5.2. 개선계획 수립
6. 영향평가서 작성

제3절 이행단계

77

1. 이행점검
 - 1.1. 개선사항 반영점검
 - 1.2. 개선계획 이행점검

부록 1. 개인정보 영향평가서 양식	79
부록 2. 개인정보 영향평가 항목(요약)	121
부록 3. 개인정보 영향평가 항목(평가표)	131
부록 4. 개인정보 영향평가 FAQ	488

제1장 총론

제1절 개인정보 영향평가 개요

제2절 용어정의 및 추진근거

제3절 개인정보 영향평가 수행절차 요약

제1절 개인정보 영향평가 개요

1. 개념

○ 개인정보 영향평가(이하 영향평가)

- 개인정보파일을 운용하는 새로운 정보시스템의 도입이나 기존에 운영 중인 개인정보 처리시스템의 중대한 변경 시
- 시스템의 구축·운영·변경 등이 개인정보에 미치는 영향(impact)을 사전에 조사·예측·검토 하여 개선방안을 도출하는 체계적인 절차

2. 목적 및 필요성

- 개인정보 처리가 수반되는 사업 추진시 해당 사업이 개인정보에 미치는 영향을 사전에 분석하고 이에 대한 개선방안을 수립하여 개인정보 침해사고를 사전에 예방

3. 평가 대상

- 일정규모 이상의 개인정보를 전자적으로 처리하는 개인정보파일을 구축·운영 또는 변경하려는 공공기관은 「개인정보 보호법」 (이하 “법”이라 한다) 제33조 및 「개인정보 보호법 시행령」(이하 “령”이라 한다) 제35조에 근거하여 영향평가를 수행

- **(5만명 조건)** 5만명 이상의 정보주체의 민감정보 또는 고유식별정보의 처리가 수반되는 개인정보파일
- **(50만명 조건)** 해당 공공기관의 내부 또는 외부의 다른 개인정보파일과 연계하려는 경우로서, 연계 결과 정보주체의 수가 50만 명 이상인 개인정보파일
- **(100만명 조건)** 100만 명 이상의 정보주체 수를 포함하고 있는 개인정보파일

※ 현시점 기준으로 영향평가 대상은 아니나 가까운 시점(1년 이내)에 정보주체의 수가 기준을 초과할 것이 확실한 경우, 영향평가를 수행할 것을 권고

- **(변경 시)** 영제35조에 근거하여 영향평가를 실시한 기관이 개인정보 검색체계 등 개인정보파일의 운용체계를 변경하려는 경우, 변경된 부분에 대해서는 영향평가를 실시

※ 법령상 규정된 대상시스템이 아니더라도 대량의 개인정보나 민감한 개인정보를 수집·이용하는 기관은 개인정보 유출 및 오·남용으로 인한 사회적 피해를 막기 위해 영향평가 수행 가능



개인정보파일 및 개인정보처리시스템 정의

○ 개인정보파일

- **(정의)** 개인정보파일은 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물(集合物)을 말한다. 개인정보파일은 데이터베이스 등 전자적인 형태뿐만 아니라 수기(手記)문서 자료도 포함하지만, 영향평가의 대상이 되는 개인정보파일은 전자적으로 처리할 수 있는 것에 한정되어 있으므로 일반적으로 종이 등의 문서에 수기로 기록된 개인정보 문서는 대상에서 제외된다. 단, 종이로 기록된 개인정보 문서가 PDF 등의 전자적인 매체로 변환될 경우 해당 PDF 파일 등은 평가의 대상이 될 수 있다.

○ 개인정보 처리시스템

- **(정의)** 개인정보처리시스템이란 데이터베이스 등 개인정보를 처리할 수 있도록 체계적으로 구성된 시스템을 말한다. 개인정보처리시스템은 일반적으로 데이터베이스(DB) 내의 데이터에 접근할 수 있도록 해주는 응용시스템을 의미하며 데이터베이스를 구축하거나 운영하는데 필요한 시스템을 말한다. 다만, 개인정보처리시스템은 개인정보처리자의 개인정보 처리방법, 시스템 구성 및 운영환경 등에 따라 달라질 수 있으며 작게는 한 대의 서버에서부터 크게는 수백 대의 서버 및 DBMS를 운영하는 것까지 다양한 규모를 가지고 있다. 영향평가에서는 개인정보처리시스템 내의 개인정보파일을 안전하게 보호하기 위하여 필요한 기술적·관리적 및 물리적 안전조치가 적절하게 적용되었는지 여부를 비롯하여 개인정보의 수집, 저장, 이용, 제공, 파기 등 생명주기 상에 관련 법규를 준수하고 정보주체의 권리를 제대로 보장하고 있는지를 확인하고 문제점이 있는 경우 개선방안을 제시하게 된다.



공공기관의 범위(법 제2조제6호)

- 국회, 법원, 헌법재판소, 중앙선거관리위원회의 행정사무를 처리하는 기관, 중앙행정기관(대통령 소속 기관과 국무총리 소속 기관을 포함한다) 및 그 소속 기관, 지방자치단체
- 그 밖의 국가기관 및 공공단체 중 대통령령으로 정하는 기관
 1. 「국가인권위원회법」 제3조에 따른 국가인권위원회
 2. 「공공기관의 운영에 관한 법률」 제4조에 따른 공공기관
 3. 「지방공기업법」에 따른 지방공사 및 지방공단
 4. 특별법에 의하여 설립된 특수법인
 5. 「초·중등교육법」, 「고등교육법」 및 그 밖의 다른 법률에 따라 설치된 각급 학교
- 단, 국회, 법원, 헌법재판소, 중앙선거관리위원회(그 소속 기관을 포함)의 영향평가에 관한 사항은 국회규칙, 대법원규칙, 헌법재판소규칙 및 중앙선거관리위원회규칙으로 정하는 바에 따름(「개인정보 보호법」 제33조 제7항)

4. 평가 시기

■ 영향평가 시기 ■



4.1. 시스템을 신규 구축 또는 기존 시스템을 변경하는 경우

- 개인정보처리시스템을 신규로 구축 하거나 기존 시스템을 변경하려는 기관은 사업계획 단계에서 영향평가 의무대상 여부를 파악하여 예산을 확보한 후, 대상 시스템의 설계 완료 전에 영향평가를 수행해야 함. 또한 영향평가 결과는 시스템 설계·개발 시 반영해야 함(「개인정보 영향평가에 관한 고시」 제9조의2)

4.2. 기 구축되어 운영 중인 시스템의 경우

- 개인정보처리시스템을 기 구축·운영 중, 아래의 경우 추가적으로 영향평가 수행 가능
 - 수집·이용 및 관리상에 중대한 침해위험의 발생이 우려되는 경우
 - 전반적인 개인정보 보호체계를 점검하여 개선하기 위한 경우

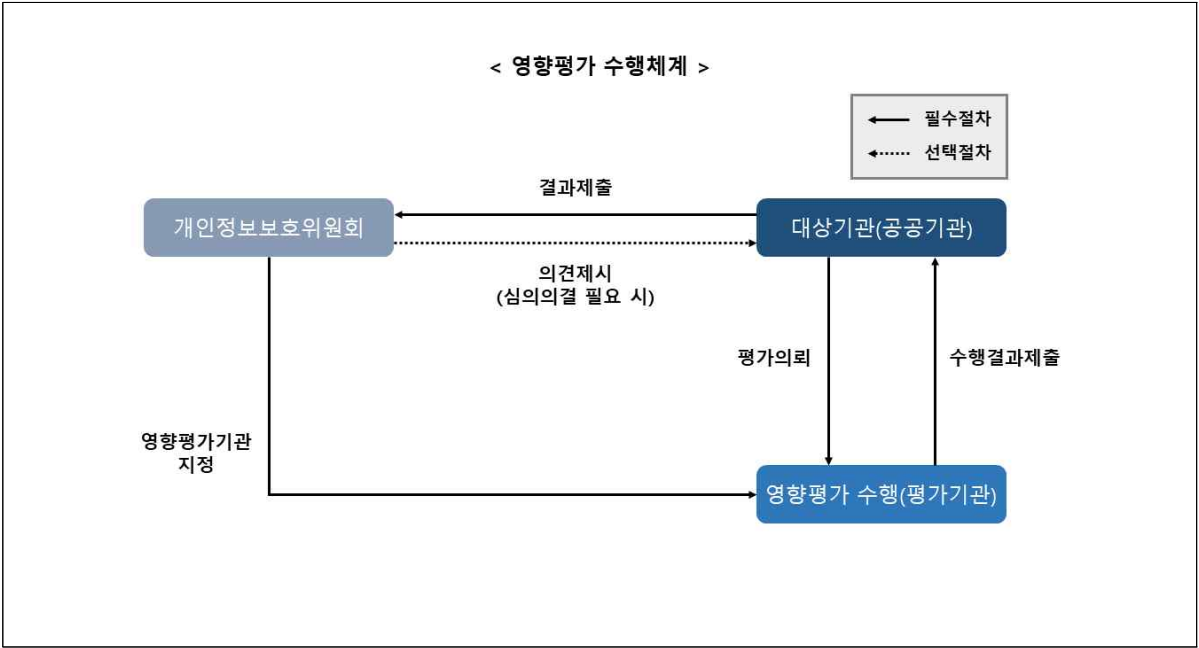
5. 평가 수행 주체

- 공공기관은 보호위원회가 지정한 영향평가기관에 평가를 의뢰하여 수행
 - ※ 영향평가기관에 대한 정보는 개인정보보호 포털(privacy.go.kr)에서 확인 가능

6. 평가 수행 체계

- 영향평가는 보호위원회가 지정한 영향평가기관에 의뢰하여 영향평가를 수행하고 그 결과를 사업 완료 후 2개월 이내에 보호위원회에 제출*
- 보호위원회는 심의·의결을 거쳐 해당 사업에 대한 의견 제시 가능
- * 개인정보보호 종합지원시스템(<https://intra.privacy.go.kr>)에 등록

■ 영향평가 수행체계 ■



제2절 용어정의 및 추진근거

1. 용어정의

○ 개인정보

: '개인정보'란 살아있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보를 말하며, 해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 개인을 알아볼 수 있는 정보가 포함된다. 이 경우 쉽게 결합할 수 있는지 여부는 다른 정보의 입수 가능성 등 개인을 알아보는 데 소요되는 시간, 비용, 기술 등을 합리적으로 고려해야 한다. 또한 개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가 정보가 없는 특정 개인을 알아볼 수 없도록 가명처리한 정보 즉, 가명정보도 개인정보에 포함됨

○ 처리

: 개인정보의 수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정(訂正), 복구, 이용, 제공, 공개, 파기(破棄), 그 밖에 이와 유사한 행위(개인정보 보호법 제2조제2호)

○ 정보주체

: 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람(개인정보 보호법 제2조제3호)

○ 개인정보파일

: 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물(集合物)(개인정보 보호법 제2조제4호)

○ 개인정보처리자

: 업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등(개인정보 보호법 제2조제5호)

○ 영상정보처리기기

: 일정한 공간에 지속적으로 설치되어 사람 또는 사물의 영상 등을 촬영하거나 이를 유·무선망을 통하여 전송하는 장치로서 대통령령으로 정하는 장치(개인정보 보호법 제2조제7호)

○ 민감정보

: 사상·신념, 노동조합·정당의 가입·탈퇴, 정치적 견해, 건강, 성생활 등에 관한 정보, 그 밖에 정보주체의 사생활을 현저히 침해할 우려가 있는 개인정보, 개인의 신체적, 생리적, 행동적 특징에 관한 정보로서 특정 개인을 알아볼 목적으로 일정한 기술적 수단을 통해 생성한 정보, 인종정보 또는 민족정보

○ 고유식별정보

: 법령에 따라 개인을 고유하게 구별하기 위하여 부여된 식별정보로서 주민등록번호, 여권번호, 운전면허번호, 외국인등록번호를 의미(개인정보 보호법 시행령 제19조)

○ 개인정보취급자

: 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 업무를 담당하는 자로서 임직원, 파견근로자, 시간제근로자 등을 말함(「표준 개인정보 보호지침」 제2조 제6호)

※ 개인정보취급자는 개인정보 처리 업무를 담당하고 있는 자라면, 정규직, 비정규직, 하도급, 시간제 등 모든 근로 형태를 불문하며, 고용관계가 없더라도 실질적으로 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 자는 개인정보취급자에 포함(개인정보 보호법령 및 지침·고시 해설 제28조)

○ 개인정보처리시스템

: 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템(「개인정보의 안전성 확보조치 기준」 제2조 제10호)

○ 위험도 분석

: 개인정보 유출에 영향을 미칠 수 있는 다양한 위험요소를 식별·평가하고 해당 위험요소를 적절하게 통제할 수 있는 방안 마련을 위한 종합적으로 분석하는 행위(「개인정보의 안전성 확보조치 기준」 제2조 제11호)

○ 개인정보 영향평가(이하 영향평가)

: 법 제33조제1항에 따라 공공기관의 장이 영 제35조에 해당하는 개인정보파일의 운용으로 인하여 정보주체의 개인정보 침해가 우려되는 경우에 그 위험요인의 분석과 개선 사항 도출을 위한 평가(「개인정보 영향평가에 관한 고시」 제2조 제1호)

○ 대상기관

: 영 제35조에 해당하는 개인정보파일을 구축·운용, 변경 또는 연계하려는 공공기관 (「개인정보 영향평가에 관한 고시」 제2조 제2호)

○ 개인정보영향평가 기관(이하 평가기관)

: 영 제37조제1항 각 호의 요건을 모두 갖춘 법인으로서 공공기관의 영향평가를 수행하기 위하여 보호위원회가 지정한 기관(「개인정보 영향평가에 관한 고시」 제2조 제3호)

○ 대상시스템

: 영 제35조에 해당하는 개인정보파일을 구축·운용, 변경 또는 연계하려는 정보시스템 (「개인정보 영향평가에 관한 고시」 제2조 제4호)

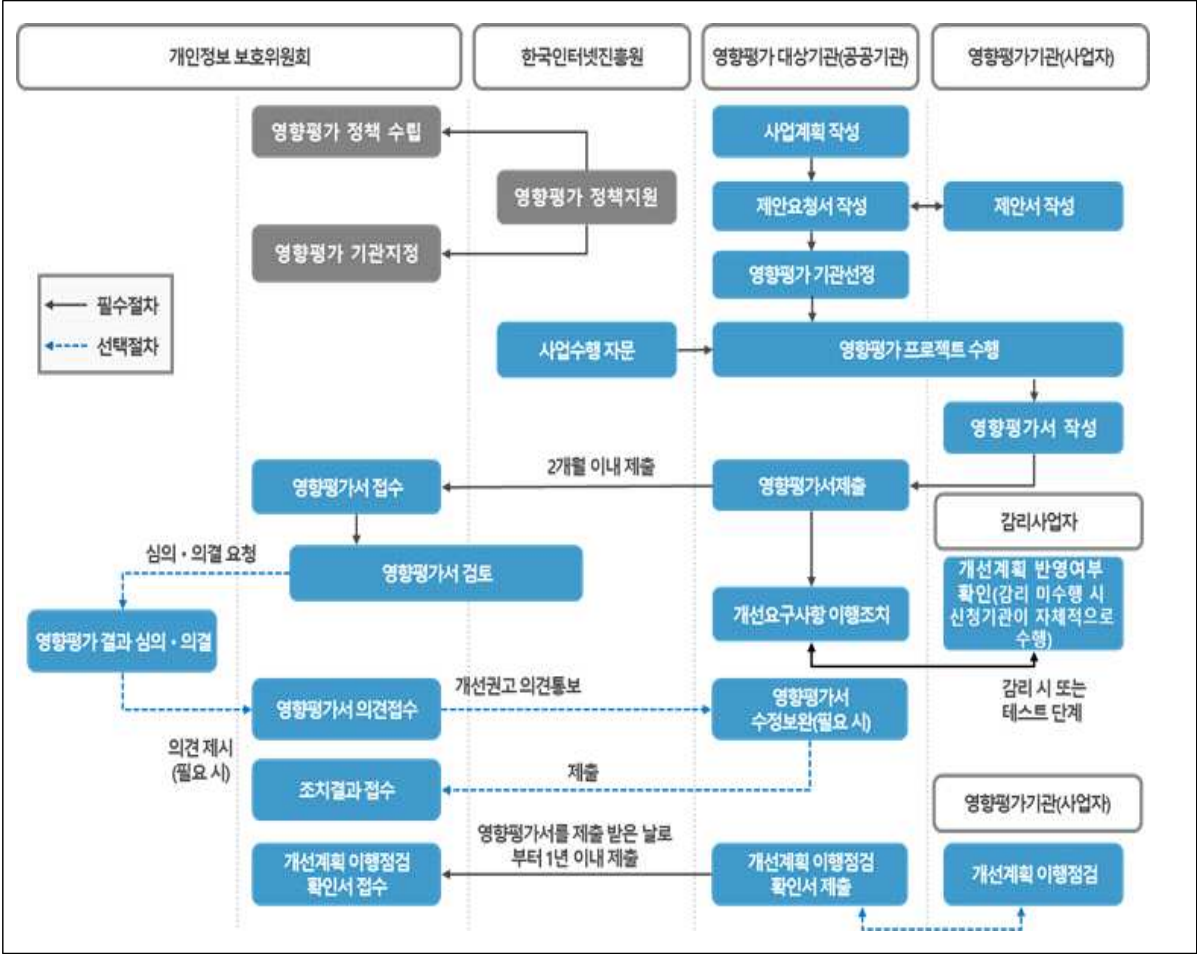
2. 추진근거

- 개인정보 보호법 제33조(영향평가)
- 개인정보 보호법 시행령 제35조(영향평가의 대상)
- 개인정보 보호법 시행령 제36조(영향평가 시 고려사항)
- 개인정보 보호법 시행령 제37조(평가기관의 지정 및 지정취소)
- 개인정보 보호법 시행령 제38조(영향평가의 평가기준 등)
- 개인정보 처리 방법에 관한 고시(개인정보보호위원회고시 제2020-7호) 제3조(개인정보 보호업무 관련 장부 및 문서 서식) [시행 2020.8.11.]
- 개인정보 영향평가에 관한 고시(개인정보보호위원회고시 제2020-4호) [시행 2020.8.11.]

제3절 영향평가 수행 절차 요약

- 영향평가 사업은 직전연도에 예산을 확보하고, 당해연도에 평가기관을 선정하여 대상기관과 평가기관이 협업을 통해 영향평가서를 완성
 - 영향평가서는 최종 제출받은 날로부터 2개월 이내에 보호위원회에 제출
 - 영향평가서를 제출한 날로부터 1년 이내에 이행점검 확인서를 보호위원회에 제출
- ※ 제출방법 : 개인정보보호 종합지원시스템(<https://intra.privacy.go.kr>)에 등록

■ 영향평가 수행 절차도 ■



제2장 영향평가 수행절차

제1절 영향평가 사전준비 단계

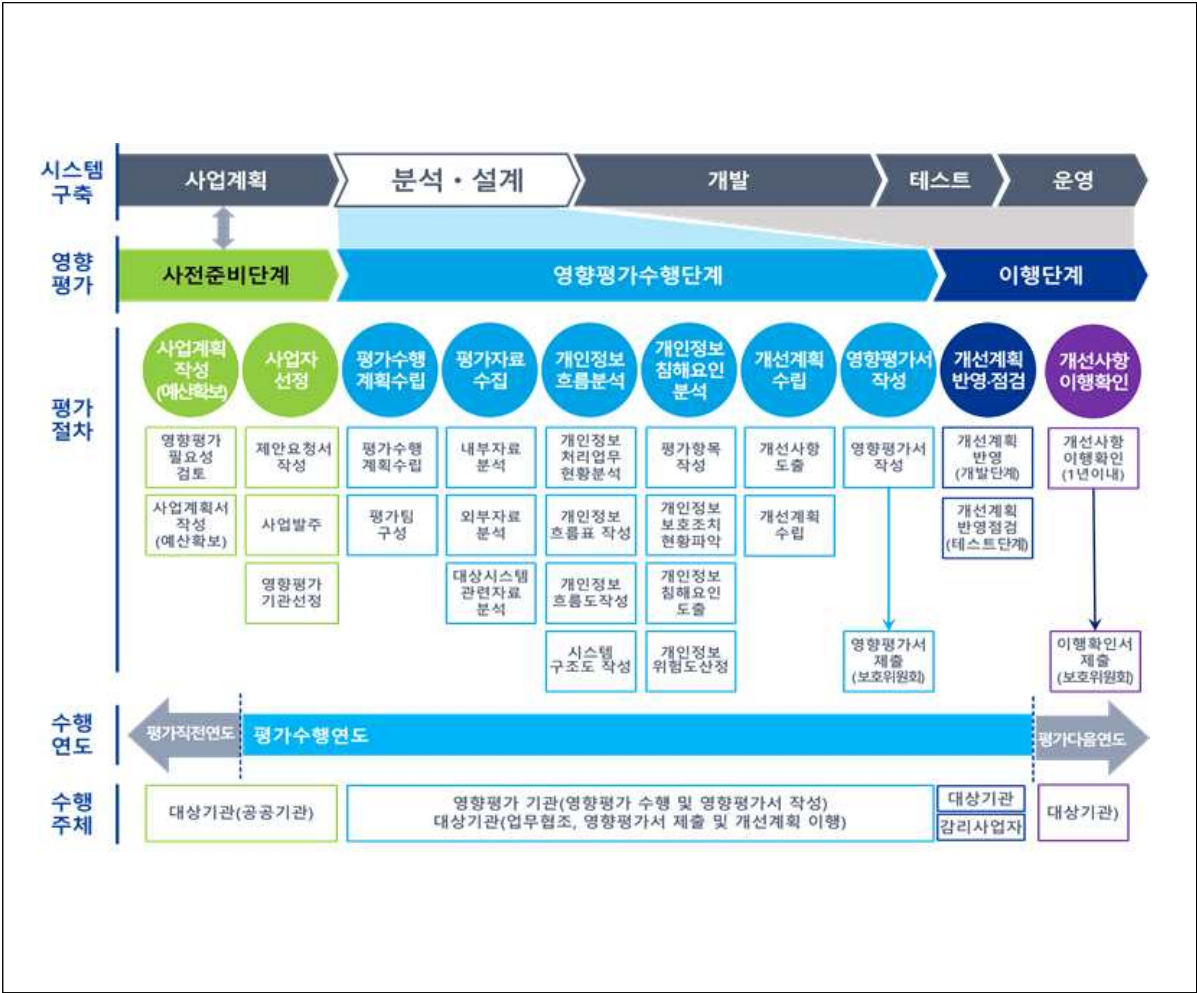
제2절 영향평가 수행단계

제3절 이행단계

○ 영향평가 사업은 사전준비 단계, 수행단계, 이행단계 등 3단계로 구성

- 영향평가 사전준비 단계 : 영향평가 사업계획을 수립하여 예산을 확보하고 평가기관을 선정
- 영향평가 수행단계 : 선정된 평가기관이 개인정보 침해요인을 분석하고 개선계획을 수립하여 영향평가서를 작성
- 이행 단계 : 영향평가서의 침해요인에 대한 개선계획을 반영하고 이를 점검

■ 영향평가 절차 ■



제1절 영향평가 사전준비 단계

1. 사업계획의 작성

1.1. 영향평가 필요성 검토

목 표	구축 또는 변경하고자 하는 정보화사업(정보시스템)에 대해 영향평가 필요성 여부 판단
개 요	정보화사업을 추진하는 과정에서 개인정보의 신규 수집·이용·연계·제공 또는 처리절차상 변경 등으로 영향평가 대상이 되는지에 대해 영 제35조에 근거하여 판단
수행주체	대상사업 주관 부서
참고자료	사업계획서, 제안요청서(RFP) 등
산 출 물	영향평가 필요성 검토서 (영 제35조에 근거하여 작성)

- 영 제35조에 근거하여 특정 정보주체 수 이상(제1장 제1절 평가대상 참조)의 개인정보를 전자적으로 처리하는 공공기관은 영향평가를 의무적으로 수행
 - 영향평가를 실시하는 3가지 유형
 - ① 개인정보파일을 신규 구축·운용 하려는 경우
 - ② 기 운용 중인 개인정보파일의 수집, 보유, 이용·제공, 파기 등 처리절차를 변경하거나 개인정보 검색체계 등 개인정보파일 운용체계를 변경하려는 경우
 - ③ 개인정보파일을 타 시스템과 연계·제공하려는 경우
- 공공기관 외의 개인정보처리자는 개인정보파일 운용으로 인하여 정보주체의 개인정보 침해가 우려되는 경우에는 자율적으로 판단하여 영향평가를 하기 위하여 적극 노력 (「개인정보 보호법」 제33조 제8항)



개인정보파일의 운용체계 변경 예시

- 기 수집된 개인정보파일의 처리절차가 변경되는 경우는 개인정보 처리시스템의 추가·변경 또는 개인정보 수집·경로, 처리절차의 확대·변경하는 경우로 구분
 - 개인정보처리시스템을 추가·변경하려는 경우 : 데이터베이스시스템 혹은 응용프로그램 등의 개인정보 처리시스템이 노후하여 이를 신규로 구축하거나 기능을 고도화 하는 경우
 - ※ 예) 교육청이 해당관할 내 학교소속 학생들의 진로상담을 위해 기존에 운용하던 정보 시스템을 신규로 구축하는 경우
 - 개인정보 수집·경로 및 처리절차를 확대·변경하려는 경우 : 기존 개인정보파일의 수집·경로가 온라인에서 오프라인까지 확대 되거나, 수집·보유·이용·제공 파기 등 개인정보 처리절차가 변경되는 경우
 - ※ 예) ○○증명서 발급을 위한 개인정보 수집을 기존 각 구청에서 전국 읍·면사무소(주민센터)로 확대하는 경우
- 기관 내부의 다른 정보시스템과 개인정보처리시스템을 새롭게 연계하거나, 기존 연계방식 또는 연계하는 데이터를 변경하는 경우
- 개인정보의 수집·방법을 기존 정보주체로부터 직접 수집하는 방식에서 간접 수집 방식으로 변경하는 경우
- 수집·처리되는 개인정보의 항목이 추가되거나 변경된 경우 또는 개인정보 수집·이용 목적에 변경이 발생하는 경우
- 기존 정보시스템에 신기술을 적용하는 등의 새로운 활용법을 채택함으로써 기존에 수집되거나 향후 수집될 정보가 본인 확인이 가능한 형태로 변경되는 등 시스템 상에 중대한 변화가 발생하는 경우
- 신규 또는 추가로 구축된 시스템이 개인정보 DB에 대한 접근을 관리 또는 통제하기 위해 사용되는 보안체계에 중대한 변화를 초래하는 경우
- 사업의 서비스 이용과정에서 생성되는 정보를 기존에 수집한 개인정보와 결합시킴으로써 정보주체의 프라이버시에 영향을 미칠 수 있는 이차적인 정보가 생성되는 경우
 - ※ 기존 업무처리 절차나 개인정보보호 체계의 변경이 없는 단순 노후장비 교체, 운영·유지보수 사업의 경우 영향평가 대상에서 제외할 수 있다.



외부기관과의 연계 예시

- 기존에 보유하고 있는 개인정보파일을 외부기관과 연계하는 경우, 새로운 개인정보파일을 연계하는 경우와 기존 연계 절차를 변경하는 경우로 구분
 - 외부기관의 요청 또는 법률 근거에 의해 개인정보파일을 외부기관과 연계·연동 혹은 이관하는 경우
 - ※ 예) 각 시·군청에서 관리하고 있는 학비지원 대상자를 상위기관인 도청에서 추가로 취합·관리하기 위해 학비지원 대상자 현황을 일정주기로 연계하여 자료를 갱신하고자 하는 경우
 - 기존 외부기관과의 개인정보파일 연계·연동 절차를 변경하려는 경우
 - ※ 예) 각 시·군청에서 관리하고 있는 자원봉사자를 상위기관인 도청에서 취합·관리하고 있는데, 취합하는 자원봉사자의 개인정보가 추가되거나, 취합절차가 기존 공문 및 명단 우편발송에서 실시간 시스템 연동으로 변경하려는 경우

1.2. 사전평가 수행(선택사항)

- 대상기관은 영향평가기관을 통해 영향평가를 수행하기 전에 영향평가 자율수행 프로그램 (privacy.go.kr)을 통해 맞보기 기능 활용 가능
 - 영향평가 맞보기 기능은 대상시스템 및 영향평가 절차 등에 대한 이해도를 높일 수 있고, 사업발주 시 평가기관에 대한 사업관리 등에 활용 가능

1.3. 사업계획서 작성

- 영향평가 사전준비 단계로 영향평가 사업계획서를 작성하고, 영향평가 예산 확보를 위해 사업계획에 포함

■ 사업계획서 및 제안요청서 목차(예시) ■

사업계획서 목차		제안요청서 목차	
I. 사업개요	1. 사업개요	1. 사업개요	I. 사업 안내
	2. 추진배경 및 필요성	2. 추진배경 및 필요성	
	3. 사업범위	3. 사업범위	
	4. 기대효과	4. 기대효과	
II. 대상업무 현황	1. 업무현황	1. 업무현황	II. 대상업무 현황
	2. 정보시스템 현황	2. 정보시스템 현황	
	3. 선진사례	3. 선진사례	
	4. 문제점 및 개선과제	4. 문제점 및 개선과제	
III. 사업추진 계획	1. 추진목표	1. 추진목표	III. 사업추진 계획
	2. 추진전략	2. 추진전략	
	3. 추진체계 및 역할	3. 추진체계 및 역할	
	4. 추진일정	4. 추진일정	
IV. 사업내용	1. 주요 사업내용	1. 주요 사업내용	IV. 제안요청 개요
	2. 세부 사업내용	2. 세부 사업내용	
V. 소요자원 및 예산		3. 용역산출물	
VI. 기타 지원요건	1. 교육지원 요건	4. 보안요건	
	2. 기술지원 요건	5. 기타지원요건	
	3. 유지보수 요건		

2. 영향평가 기관 선정

목 표	기관의 영향평가를 수행할 평가기관을 선정
개 요	보호위원회가 지정한 영향평가기관을 대상으로 평가기관을 선정 제안요청서를 작성하고, 사업발주 후 평가기관 중 적합한 기관을 선정
수행주체	사업주관부서 (영향평가 주관부서)
참고자료	각 기관 업무분장
산 출 물	제안요청서(대상기관), 제안서(영향평가기관)

2.1. 제안요청서 작성 및 사업발주

- 사업계획서에 기반하여 영향평가 사업발주를 위한 제안요청서를 작성



사업발주 시 주의사항

- 제안요청서 작성 시 영향평가 대상 시스템의 설계 완료 전에 영향평가를 수행하도록 일정 계획을 제시하여야 하며, 영향평가 개선계획의 반영여부를 감리 또는 테스트 단계에서 확인할 수 있도록 사업 발주 필요
 - 대상 시스템의 설계 완료 전에 영향평가 수행
 - 영향평가 개선계획의 반영여부를 정보시스템 감리 시 확인해야 하므로, 정보시스템 감리 사업발주 시 관련 요건을 포함하여 발주 필요 단, 감리를 수행하지 않은 경우에는 정보시스템 테스트 단계에서 영향평가 개선 계획의 반영여부를 확인
 - 공공기관의 장은 개선사항으로 지적된 부분에 대한 이행 현황을 영향평가서를 제출받은 날로부터 1년 이내에 보호위원회에 제출해야 하므로, 필요시 관련 요구 사항을 제안요청서에 포함
- 시스템 구축 사업의 일부분으로써 영향평가를 포함하여 발주할 경우 영향평가의 독립성을 심각하게 저해 할 수 있으므로, 구축사업과 분리하여 별도의 사업으로 발주 필요
 - 다만 불가피하게 시스템 구축 사업의 일부로 발주하거나 개인정보보호컨설팅 사업의 일부로 발주하는 경우, 영향평가 사업비용은 별도 분리해야 하며 독립성이 훼손되지 않도록 사업 추진 필요
 - 정보시스템 구축사업을 감리한 업체가 동일한 사업에 대한 영향평가 수행은 불가
 - 정보시스템 구축사업을 수행한 사업자가 동일한 사업에 대해서 영향평가 사업을 수행하는 것은 불가
- 대상기관은 제안서 평가 시 투입인력의 인증서 보유 여부 확인 필요
 - 영향평가 사업은 인증서 보유 등 자격요건을 갖춘 인력만 수행 가능

- 투입인력은 평가기관에 소속되지 않더라도 전체 인력의 50% 미만에 한해 인증서를 보유한 프리랜서나 타사 인력 활용 가능

※ 인증서 보유여부는 개인정보보호 포털(privacy.go.kr) 영향평가 수행인력 조회메뉴에서 인증번호를 사용하여 조회가능

2.2. 영향평가 기관 선정

- 영향평가기관 중 제안요청사항을 충족할 수 있는 적정 기관을 선정하되, 다음과 같은 문제점이 있으면 평가 수행 업체로 부적절하므로 선정시 유의

- 영 제37조(평가기관의 지정 및 지정취소)제5항 및 영향평가 고시 제8조(사후관리)에 따라 **보호위원회로부터** 개선권고, 경고, 지정취소 등을 받은 경우

제2절 영향평가 수행단계

1. 영향평가 수행계획 수립

목 표	효율적인 평가 수행을 위해 사전 계획 수립
개 요	사업 주관 부서가 영향평가 수행계획을 수립하고, 수립한 계획서는 착수회의를 통하여 영향평가팀은 물론 당해 사업과 관련하여 협조가 필요한 유관 부서, 외부 기관, 외부 전문가 등과 공유
수행주체	영향평가 팀
참고자료	영향평가 수행계획서 작성 예시
산 출 물	영향평가 수행계획서

1.1. 영향평가 수행계획 수립

- 영향평가팀은 평가과정에 필요한 사항들을 정리하고 영향평가팀 내에서 공유할 수 있는 세부적인 영향평가 수행계획을 수립하여 “영향평가 수행계획서”를 작성
- 영향평가 수행계획서에는 다음과 같은 사항을 반영
 - 영향평가 수행계획서 내 반영 사항 : 평가목적, 평가대상 및 범위, 평가주체(영향평가팀), 평가기간, 평가절차(방법), 주요 평가사항, 평가기준 및 항목, 자료수집 및 분석계획 등
- 개인정보 보호책임자 등에 영향평가 수행계획서를 보고하고, 영향평가 대상사업 최종 책임자의 영향평가 수행 지시 후 평가를 실시
 - 영향평가의 필요성 공유 및 원활한 업무협조를 위해 당해 정보화사업과 관련된 유관부서 및 외부기관 등과 함께 착수회의를 실시

■ 영향평가 수행계획서 작성 예시 ■

목차	주요 내용	참고자료
1. 평가 목적	영향평가 수행 필요성 및 추진 배경 등을 기술	필요성 검토 질문서
2. 평가 대상	평가대상이 되는 정보화사업(정보시스템)명칭 기술	제안요청서(RFP), 사업계획서 등
3. 평가 주체	영향평가팀 구성 현황	영향평가팀 구성 및 운영 계획서
4. 평가 기간	영향평가 착수시점부터 완료시점까지의 평가기간을 산정하여 기술	영향평가기관 선정 단계에서 산출물 및 협의내용, 영향평가 수행안내서 참고
5. 평가 절차(방법)	영향평가 수행안내서 등을 참조하여 평가 절차 및 단계별 주요 수행사항 및 기간 등 기술	
6. 주요 평가사항	중점적으로 평가되어야 하는 사항 기술	
7. 평가기준 및 평가항목	영향평가 수행안내서에서 표준적으로 요구되는 평가항목 (표)와 해당 사업의 특정 IT 기술 활용 여부 확인 ※ 부록으로 영향평가 항목 첨부	
8. 자료수집 및 분석계획	영향평가 수행 시 분석하여야 하는 관련 참고자료를 확인하여 해당 기관과 관련 있는 자료 파악	개인정보 관련 정책, 법규 검토 단계의 산출물 참조
9. 평가결과의 정리	영향평가 결과로 도출된 산출물(보고서)과 이를 활용하여 당해 사업에 적용하기 위한 방안 등 기술	영향평가팀 회의 내용 등 참조
10. 품질관리 방안	영향평가 결과의 품질 보장을 위한 상세 방안 기술	영향평가 품질검토 체크리스트 등 참고

1.2. 영향평가팀 구성방안 협의

○ 평가기관의 PM(Project Manager : 프로젝트 책임자)은 대상기관 사업관리 담당자의 협조 하에 개인정보보호 담당자, 유관부서 담당자, 외부전문가 등의 참여를 요청

- 위탁 개발·관리되고 있는 정보시스템의 경우에는 실제 업무담당자와 사업담당자가 다르므로 현업 업무담당자는 반드시 참여
- 공공기관이 사업을 추진하나 실제 정보화사업 운영·관리를 산하기관 등 외부기관이 주관한다면 해당 산하기관 담당자 참여
- 외부 정보시스템 구축업체에 용역을 의뢰하여 구축사업을 추진 시, 프로젝트관리자(PM) 또는 파트리더(PL) 등이 참여

1.3 영향평가팀 역할 정의

○ 영향평가팀의 평가기관 PM은 각 구성원의 역할 및 책임 사항을 배분

- 영향평가팀원으로 참여하는 담당자의 업무를 정의하고, 사업관련 자료를 명확히 하여 업무의 중복 지양

○ 다음 표는 영향평가 단계별로 영향평가팀의 역할관계를 정의한 것으로서, 이를 참조하여 역할 배분 가능

- 영향평가팀은 대상기관 사업주관부서와 기관 내 유관부서 및 외부기관, 사업구축 부서를 기본적으로 포함

※ 외부용역을 통해 개발하는 경우, 정보시스템 개발업체(개발용역업체)를 포함

- 개인정보보호를 위한 법률해석의 자문이 필요하거나 전문가의 조언이 필요한 경우, 외부 자문위원 포함 가능

○ 영향평가기관의 평가수행 인력은 반드시 상주, 품질관리 담당자는 비상주 가능

- 영향평가 업무의 연속성 확보 및 품질 제고를 위해 투입인력 중 최소 1명 이상은 업무분석 단계부터 위험분석, 개선계획 도출 등 사업 전기간 동안 상주

■ 영향평가팀 역할 구분 ■

구분	역 할
개인정보 보호책임자	- 영향평가 총괄
대상기관 사업주관부서	- 영향평가 사업관리 - 영향평가 사업 진행 단계별 산출물 등에 대한 품질관리·검토 - 기관 내 업무 유관부서 협력요청 - 영향평가팀 착수회의, 중간보고 및 종료회의 등 공식 회의 주관 - 개선계획 이행 관리 및 확인
영향평가기관	- 평가계획 수립 - 영향평가 팀 구성 - 영향평가 사업 수행 - 평가업무 간 수집된 자료와 산출물에 대한 보안관리, 품질관리 - 평가를 위한 중간 산출물 및 영향평가서 작성 - 영향평가 이행점검(발주기관 요청 시)
유관 부서, 외부기관	- 당해 사업 관련 자료 및 영향평가팀이 요청하는 자료의 제공 - 영향평가팀 요청에 의한 인터뷰 참여 - 개인정보 흐름분석 결과 검토 및 의견제시 - 영향평가서의 검토 및 의견 제공
시스템 개발부서	- 당해 사업 관련 자료 및 영향평가팀이 요청하는 자료 제공 - 영향평가팀 요청에 의한 인터뷰 참여 - 개인정보 흐름분석 결과 검토 및 의견제시 - 영향평가서의 검토 및 의견 제공 등 - 평가결과에 대한 개선 수행 ※ 시스템개발을 직접 수행하지 않는 경우, 외부 개발업체 담당

■ 영향평가팀 업무 배분 예시 ■

업무	담당	평가 기관	대상기관 사업주관 부서	정보통신 또는 보안 담당관	시스템 개발자 또는 운영자	분야별 개인정보 보호 책임자	개인정보 보호 책임자	최고의사 결정권자	기타
영향평가 필요성 검토			●			◎	◇		
개인정보관련 정책, 법규 및 사업내용 검토			●	◎		◎			외부 용역 업체,
개인정보 흐름 분석			●	◎	◎	◎			
개인정보 침해요인 및 위험평가			●	◎	◎	◎			외부 전문가 참여 가능
개선계획 수립			●	◎	◎	◎			
영향평가서 작성			●			◎	◇		
영향평가서 검수 및 제출			●			◎	◎	◇	
개선계획 이행 관리	◎		●	◎	◎	◎	◎	◇	

● : 업무 주관, ◎ : 지원, ◇ : 승인 및 의사결정



참여자별 역할비교(참고)

○ 개인정보 보호책임자, 보안담당관, 정보통신보안담당관의 고유한 역할과 영향평가팀 내에서의 역할

구분	고유 역할	영향평가팀 내 역할
개인정보 보호책임자 (개인정보 총괄관리자)	1. 개인정보 보호 계획의 수립 및 시행 2. 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선 3. 개인정보 처리와 관련한 불만의 처리 및 피해 구제 4. 개인정보 유출 및 오용·남용 방지를 위한 내부통제시스템의 구축 5. 개인정보 보호 교육 계획의 수립 및 시행 6. 개인정보파일의 보호 및 관리·감독 7. 개인정보 처리방침의 수립·변경 및 시행 8. 개인정보 보호 관련 자료의 관리 9. 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기	- 영향평가 필요성 및 수행 계획의 적절성 검토 - 점검 기준에 개인정보보호 관련 유관 법률·지침 및 기관 내 규정 등이 적절히 반영되었는지 여부 검토 - 개인정보 처리방침의 내용 검토 - 사업 착수 또는 수행 시 개인정보보호 교육의 시행 - 사업완료 후 시스템 사용자에게 대한 개인정보보호 교육계획 수립 - 영향평가 개선계획의 이행 관리 및 반영여부 확인
보안담당관	1. 연도별 보안업무추진계획 수립 및 심사 분석(보안관련 주요 성과 및 실적분석) 2. 보안(인원, 시설, 문서, 자재 등) 진단 3. 보안교육에 관한 사항 4. 비밀소유 및 처리인가자 현황조사 5. 보안서약의 집행 6. 통신보안에 관한 업무(음어·약호자재) 7. 출입통제 등 자체 방호계획 수립, 시행 8. 보안업무 기획 및 조정 등 * 국가정보보안기본지침 제5조(정보보안담당관 운영)제4항	- 평가팀에 대한 보안관리 요구사항 검토 - 보안서약, 평가팀 업무 공간 보안점검, 문서보안 등 - 평가대상사업에 따라 시스템이 설치될 공간에 대한 물리적인 보안(출입통제, CCTV 등) 요건 검토
정보통신 보안담당관	1. 정보통신 보안활동 계획 수립 2. 정보통신망 신·증설 시 보안대책 수립 3. 정보통신실 정보통신망 및 정보자료 등의 보안관리 4. 정보통신 보안업무 지도, 감독 및 교육 5. 정보통신 보안사고 조사 및 처리 6. 정보통신시스템의 보안관리 7. 정보통신 보안업무 심사분석 관장 8. 정보통신 보안관련 지침 등 제도 개선 9. 정보통신망 취약성 진단 10. 정보통신시스템의 보안관리 11. 기타 정보통신 보안관련 업무	- 대상사업에서 소요되는 정보시스템(서버, 네트워크, 보안장비 등) 및 관련 정보자산의 보안요건 검토 및 보안취약성 (사전)진단 - 응용프로그램 설계 및 개발 시 보안 요구사항 검토 - 웹서버 등의 공개서버에 대한 네트워크 보안 요건 검토 - 기타 개인정보의 노출 및 유출 가능성 진단과 이에 따른 보호대책 검토

1.4 영향평가팀 운영계획 수립

- 영향평가팀 구성과 각 구성원의 역할 및 책임 사항의 정의가 완료되면 이를 문서화한 영향평가팀 구성·운영계획서”를 작성
 - 영향평가팀 구성·운영계획서는 평가팀원이 내부적으로 공유하여 상호간의 역할과 업무를 재확인

■ 영향평가팀 구성·운영계획서 예시 ■

사업명	문화건강 포털사이트 구축사업에 대한 영향평가			
작성자	영향평가팀			
영향평가팀 구성	담당업무	성명	소속	인증번호 ¹⁾
	영향평가 총괄	김○○	대상기관 업무 총괄	
	영향평가 수행총괄	홍○○	평가기관 PM	2000-000
	정책 및 법적요건 검토	정○○	대상기관 업무담당자	
		김XX	평가기관 업무담당자	2000-000
	개인정보 흐름분석	김○○	대상기관 업무담당자	
		이XX	평가기관 업무담당자	2000-000
	시스템 및 네트워크 분석	강○○	대상기관 업무담당자	
		박XX	평가기관 업무담당자	2000-000
	...	...	...	...
상세업무정의	• 담당업무의 상세업무 정의			
운영계획	• 평가팀 운영 원칙, 회의 주기 및 횟수 등 명시 • 평가에 필요한 자원(예산, 자료, 공간 등) 확보에 관한 내용			
추진일정	• 평가계획의 수립부터 영향평가서 작성까지의 일정 작성			

1) 인증번호 : 영향평가 전문교육 이수 및 시험을 통과한 인력에게 부여되는 인증번호로서 유효한 인증번호를 발급받은 인력만이 영향평가를 수행할 수 있음

2. 평가자료 수집

목 표	대상사업 및 개인정보보호 관련 기관 내·외부 정책환경 분석을 위한 자료 수집
개 요	개인정보보호 관련 법규 및 상위기관의 지침과 해당기관 내부규정 현황을 파악하고 당해 사업을 이해하고 분석하기 위해 필요한 자료 등 취합 및 분석
수행주체	영향평가팀
참고자료	참고자료 없음
산 출 물	평가 시 고려해야 하는 개인정보보호 관련 법률·규정 목록, 사업개요서 등

○ 효율적인 영향평가 수행을 위해 평가 대상 및 개인정보 정책 환경을 분석하기 위한 관련 자료 수집 필요

- 분석 대상자료는 기관 내·외부 개인정보보호관련 규정, 정책환경을 분석하기 위한 ①내부 정책자료, ②외부 정책자료 ③대상시스템 관련자료 등으로 구분

■ 분석 자료 ■

항목	수집 목적	수집 대상 자료
① 내부 정책 자료	▶ 기관 내부의 개인정보보호 체계, 규정, 조직 현황 등 분석	- 기관 내 개인정보 보호 규정 - 기관 내 정보보안 관련 규정 - 기관 내 직제표 등
	▶ 개인정보취급자(정보시스템 관리자, 접근자 등), 위탁업체 등에 대한 내부 규정 및 관리·교육 체계 확인	- 개인정보 관련 조직 내 업무 분장표 및 직급별 권한 - 정보시스템의 접근권한에 대한 내부 규정 - 위탁업체 관리 규정 등 - 시스템 관리자 및 정보취급자에 대한 교육계획
② 외부 정책 자료	▶ 개인정보보호 정책 환경 분석	- 개인정보 보호법, 관련 지침 등 - 개인정보보호 기본계획 등
	▶ 영향평가 대상사업의 특수성을 반영한 정책 환경 분석	- 평가대상사업 추진 근거 법률 및 개인정보 보호 관련 법령
③ 대상 시스템 관련 자료	▶ 정보시스템을 통해 수집되는 개인정보의 양과 범위가 해당 사업 수행을 위해 적절한지 파악	- 사업 수행 계획서, 요건정의서 - 제안서, 업무기능분해도 - 업무흐름도, 화면설계서
	▶ 정보시스템의 외부연계 여부 검토	- 위탁 계획서, 연계 계획서 - 인터페이스 정의서 - 메뉴 구조도
	▶ 정보시스템의 구조와 연계된 개인정보 보호 기술 현황 파악	- 침입차단시스템 등 보안 시스템 구조도 - 인터페이스 정의서

2.1 내부 정책자료 분석

- 대상기관의 개인정보보호 관리체계 및 규정 수립·이행 여부는 중요
- 내부 정책자료는 개인정보보호 관리체계 분석을 위한 개인정보처리방침, 개인정보 보호 정책 관련 자료, 정보보안환경 분석을 위한 시스템 구조도 등이 해당



내부 정책자료(예시)

- (조직·체계 자료) 기관별 개인정보 보호지침, 개인정보보호 내부관리계획, 개인정보 처리방침, 개인정보보호업무 관련 직제표, 개인정보보호규정, 정보보안규정 등
- (인적 통제·교육 자료) 개인정보 관련 조직 내 업무분장표 및 직급별 업무 권한 현황, 정보 시스템의 접근권한에 대한 내부규정, 시스템 관리자 및 개인정보취급자에 대한 교육계획, 위탁업체 관리규정 등
- (정보보안 자료) 방화벽 등 침입차단시스템 및 백신프로그램 도입현황, 네트워크 구성도 등

2.2 외부 정책자료 분석

- 외부 정책자료는 공통적으로 해당되는 일반 정책자료와 대상사업에 제한적으로 적용되는 특수 정책자료가 있으며 유형은 법령, 지침, 가이드라인, 훈령 등으로 다양
 - 영향평가는 규정 준수 여부와 더불어 개인정보보호 관점에서 정보시스템을 평가·분석하므로 지침이나 가이드라인 등의 권고사항을 반영하여 평가 필요
- 개인정보보호 관련 법규 준수 여부(Compliance)를 판단할 근거자료의 확보
 - 각종 개인정보보호관련 법규 등을 분석하여 대상사업관련 외부의 개인정보보호 정책환경을 파악
 - ※ 영향평가 관련 규정은 개인정보보호 포털(privacy.go.kr)에서 확인 가능

■ 개인정보보호 관련 주요 법규 ■

관련 법규	주요 내용
개인정보 보호법	개인정보 처리 과정상의 정보주체와 개인정보처리자의 권리·의무 등 규정 ※ 공공·민간 구분 없이 모든 개인정보처리자에게 적용함
신용정보의 이용 및 보호에 관한 법률	개인 신용정보의 취급 단계별 보호조치 및 의무사항에 관한 규정 ※ 신용정보를 취급하는 금융회사(은행, 보험, 카드 등) 에게 적용함
위치정보의 보호 및 이용 등에 관한 법률	개인위치정보 수집, 이용·제공 파기 및 정보주체의 권리 등 규정
표준 개인정보 보호지침	개인정보취급자 및 처리자가 준수하여야 하는 개인정보의 처리에 관한 기준, 개인정보 침해의 유형 및 예방조치 등에 관한 세부사항 규정
개인정보의 안전성 확보조치 기준	개인정보처리자가 개인정보를 처리함에 있어서 개인정보가 분실·도난·유출·변조·훼손되지 아니하도록 안전성을 확보하기 위하여 취하여야 하는 최소한의 기준 규정
개인정보 영향평가에 관한 고시	영향평가 수행을 위한 평가기관의 지정 및 영향평가의 절차 등에 관한 세부기준 규정
개인정보 위험도 분석 기준	개인정보 처리시스템의 보호수준을 진단하여 암호화에 상응하는 조치필요 여부를 판단할 수 있는 기준을 규정

○ 기본적인 개인정보보호 규정 외에 특정 분야에만 적용되는 규정 검토가 필요하며 각 기관의 해당 업무에 관한 개인정보보호지침, 가이드라인 등도 검토 필요

- 예를 들면 교육 분야는 「교육기본법」 및 「초·중등교육법」 내의 개인정보보호 관련 규정, 「교육기관 및 교육행정기관의 개인정보보호 업무 지침」 검토 필요
- 평가대상사업이 민원 업무인 경우 「민원사무처리에 관한 법률」 검토 필요

■ 특정 IT 기술 관련 규정 ■

관련 지침	주요 내용
RFID 프라이버시 보호 가이드라인	RFID 활용 시 개인정보보호 조치 사항
위치정보의 보호 및 이용 등에 관한 법률 위치정보의 관리적·기술적 보호조치 가이드라인	위치정보 수집 및 이용 시 개인정보보호 조치 사항
바이오정보 보호 가이드라인	지문, 홍채 등 생체 정보 수집·이용 시 개인정보 보호 조치 사항

2.3 대상시스템 관련 자료 분석

- 대상사업의 추진배경, 추진목표, 사업개요 및 사업에 영향을 미치는 제반 사항에 대한 검토·분석을 실시하고, 사업 내용을 이해할 수 있도록 ‘사업개요서’를 작성
 - 사업추진계획서, 제안요청서(RFP), 과제수행계획서, 요구사항 정의서 등 다양한 형태의 사업 설명자료를 참조
 - 기 구축된 개인정보 처리시스템은 업무매뉴얼 등으로 검토 가능하며, 사업관련 자료 분석을 위한 수집내용은 영향평가 수행 시 활용되므로 상세히 검토
 - 대상기관의 정보화사업 및 개인정보 수집·이용이 법률에 근거하여 추진하는 경우가 많으므로, 관련 법률근거를 조사하고 사업개요서 내에 반영



사업 설명자료(예시)

- **(사업수행자료)** 사업추진계획서, 제안요청서, 과제수행계획서, 요구사항 정의서, (기 구축 시) 업무매뉴얼 등
- **(외부연계)** 위탁계획서, 연계계획서, 인터페이스 정의서, 아키텍처 설계서 등
- **(개발 산출물)** 시스템 설계서, 요건 정의서, 업무 흐름도, 기능 정의서, ERD(Entity Relationship Diagram), DFD(Data Flow Diagram), 유스케이스 다이어그램(Use Case Diagram), 시퀀스 다이어그램(Sequence Diagram), 테이블 정의서, 화면 설계서, 메뉴 구조도, 아키텍처 설계서, 시스템 구조도 등

3. 개인정보 흐름 분석

목 표	대상사업에서 처리되는 개인정보 흐름에 대한 파악을 위해 정보시스템 내 개인정보 흐름 분석
개 요	① 개인정보 처리업무 분석 (개인정보 영향도 등급표, 개인정보 처리업무표 및 업무 흐름도 작성) ② 개인정보 처리 업무표를 기반으로 개인정보 흐름표 작성 ③ 개인정보 흐름표를 기반으로 개인정보 흐름도 작성 ④ 기관 내 네트워크 및 보안시스템 구조 등을 분석하여 정보시스템 구조도 작성
수행주체	영향평가팀
참고자료	개발관련 산출물, 해당 업무 매뉴얼
산 출 물	개인정보 영향도 등급표, 개인정보 처리업무표, 개인정보 처리업무 흐름도, 개인정보 흐름표, 개인정보 흐름도, 정보시스템 구조도

○ 개인정보 흐름분석은 4단계로 진행

① 개인정보 처리업무 분석

- 영향평가 대상 업무 중에서 개인정보 처리업무를 도출하여 평가범위를 선정
- 개인정보를 처리(수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정, 복구, 이용, 제공, 공개, 파기 등)하는 모든 업무를 파악

② 개인정보 흐름표 작성

- 개인정보의 수집, 보유, 이용·제공, 파기에 이르는 Life-Cycle별 현황을 식별하여 개인정보 처리현황을 명확히 알 수 있도록 흐름표 작성

③ 개인정보 흐름도 작성

- 개인정보흐름표를 바탕으로 개인정보의 수집, 보유, 이용·제공, 파기에 이르는 Life-Cycle별 현황을 식별하여 개인정보 처리현황을 명확히 알 수 있도록 흐름도 작성

④ 정보시스템 구조도 작성

- 개인정보 처리시스템, 개인정보 내·외부 연계시스템 및 관련 인프라의 구성 파악
- 다른 단계와 병렬 진행 가능하며, 분석 초기에 작성하여 타 단계 진행 시 참고 가능

※ 흐름분석 및 개선계획 수립 단계와 관련하여 본 수행안내서에서 제시된 양식(표, 그림 등)은 예시로서, 영향평가 기관의 자체 방법론에 따라 대상 사업의 특성 등을 고려하여 양식을 추가 또는 일부 변형하여 사용할 수 있음(단 각 단계별 기본 절차는 준수하여야 하며, 영향평가 품질 측면에서 각 절차의 취지 및 목적을 달성할 수 있도록 하여야 함)

■ 개인정보 흐름 분석 단계 별 세부 절차 ■



영향평가서에 산출물로 기록 필요

3.1 개인정보 처리업무 현황 분석

- 개인정보 처리업무 현황 분석을 위해서는 평가자료 수집 단계에서 수집한 산출물 분석을 수행하고 업무 담당자 인터뷰 및 현장 실사 등을 통해 업무이해
 - 조직도(대상기관, 개발 조직, 운영조직 등) 및 업무분장표 등을 참조하여 인터뷰 대상자를 선정하고 계획을 수립
 - 인터뷰 대상자는 시스템 개발, 운영 담당자 및 현장 업무담당자를 포함하여야 하며, 개인정보 처리 업무 분석을 위해 필요하다고 판단되는 대상자도 포함
 - 기 운영 중인 시스템의 경우에는 시스템 실사를 통해 산출물 및 인터뷰 내용의 정합성과 누락 사항 존재 여부 등에 대해 검증
 - 실사는 업무 현장 실사와 화면·DB 등에 대한 시스템 실사로 진행
- 자료분석, 인터뷰 및 현장실사를 병행하여 분석한 결과를 기반으로 개인정보 처리 업무를 식별
- 식별된 개인정보 처리업무 별로 개인정보 항목에 대한 중요도 평가를 위해 개인정보 영향도 등급표를 작성하고 등급표에 따라 영향도를 평가

■ 개인정보 영향도 등급표 예시 ■

등급	조합설명	위험성	자산 가치	분류	개인정보 종류
1등급	그 자체로 개인의 식별이 가능하거나 매우 민감한 개인정보 또는 관련 법령에 따라 처리가 엄격하게 제한된 개인정보	- 정보주체의 경제적/사회적 손실을 야기하거나, 사생활 을 현저하게 침해 - 범죄에 직접적으로 악용 가능 - 유출 시 민/형사상 법적 책 임 부여 가능 및 대외 신 인도 크게 저하	5	고유식별정보	주민등록번호, 여권번호, 운전면허번호, 외국인등록번호 ※ 개인정보 보호법 제24조 및 동법 시행령 제19조
				민감정보	사상·신념, 노동조합·정당의 가입·탈퇴, 정치적 견해, 병력(病歷), 신체적· 정신적 장애, 성적(性的) 취향, 유전자 검사정보, 범죄경력정보, 개인의 신체적, 생리적, 행동적 특징에 관한 정보로서 특정 개인을 알아볼 목적으로 일정한 기술적 수단을 통해 생성한 정보, 인종이나 민족에 관한 정보 ※ 개인정보 보호법 제23조 및 동법 시행령 제18조
				인증정보	비밀번호, 바이오정보(지문, 홍채, 정맥 등) ※ 개인정보의 안전성 확보조치 기준 고시 제2조
				신용정보/ 금융정보	신용카드번호, 계좌번호 등 ※ 신용정보의 이용 및 보호에 관한 법률 제2조, 제1호 가목, 제1의2호, 제2호
				의료정보	건강상태, 진료기록 등 ※ 의료법 제22조·제23조 및 동법 시행규칙 제14조 등
				위치정보	개인 위치정보 등 ※ 위치정보의 보호 및 이용 등에 관한 법률 제2조, 제16조 등
				기타 중요정보	해당 사업의 특성에 따라 별도 정의
2등급	조합되면 명확히 개인의 식별이 가능한 개인정보	- 정보주체의 신분과 신상정보 에 대한 확인 또는 추정 가능 - 광범위한 분야에서 불법적 인 이용 가능 - 유출시 민/형사상 법적 책임 부 여 가능 및 대외 신인도 저하	3	개인식별정보	이름, 주소, 전화번호, 핸드폰번호, 이메일주소, 생년월일, 성별 등
				개인관련정보	학력, 직업, 키, 몸무게, 혼인여부, 가족상황, 취미 등
				기타 개인정보	해당 사업의 특성에 따라 별도 정의
3등급	개인식별정보와 조합되면 부가적인 정보를 제공하는 간접 개인정보	- 정보주체의 활동 성향 등 에 대한 추정 가능 - 제한적인 분야에서 불법적 인 이용 가능 - 대외 신인도 다소 저하	1	자동생성정보	IP정보, MAC주소, 사이트 방문기록, 쿠키(cookie) 등
				가공 정보	통계성 정보 등
				제한적 본인 식별 정보	회원번호, 사번, 내부용 개인식별정보 등
				기타 간접 개인정보	해당 사업의 특성에 따라 별도 정의

※ 서로 다른 등급의 개인정보가 혼재한 경우, 상위 등급의 개인정보로 선정

※ 영향도의 산정은 영향평가 기관의 고유 방법론에 따라 달라질 수 있으며 개인정보 영향도 등급표 예시에 따른 등급(1~3등급) 또는 자산가치(5, 3, 1)의 값을 정하여 사용 가능

○ 개인정보 처리업무를 구분하여 개인정보 처리 업무표를 작성

- 업무별로 처리하는 개인정보의 누락이나 오류사항이 없도록 철저히 검토
- 개인정보 처리 업무별 개인정보 영향도 등급표에 따라 영향도 산정

■ 개인정보 처리 업무표 양식 ■

평가업무명 ¹⁾	처리 목적 ²⁾	처리 개인정보 ³⁾	주관부서 ⁴⁾	개인정보 건수 ⁵⁾	개인정보 영향도 ⁶⁾



개인정보 처리 업무표 양식 설명

1) 평가업무명

- 영향평가 대상시스템에서 개인정보가 처리되는 업무를 주요 업무단위로 기재
- ※ 개인정보에 대한 관리가 가능한 범위로 유사한 업무단위로 묶어 단위업무를 구성
- ※ 평가업무를 너무 포괄적으로 분류할 경우 평가가 부실하게 수행될 가능성이 있으므로, 중요하거나 복잡한 업무는 세분화하여 분류함으로써 평가의 구체성을 높일 필요가 있음

2) 처리 목적

- 업무에서 개인정보를 처리하는 목적 및 사유를 기재
- ※ 개인정보처리방침이나 개인정보 수집 및 이용 동의 절차에 명시된 '개인정보의 수집·이용 목적'을 참고하여 조사 가능

3) 처리 개인정보

- 영향평가의 평가업무 단위로 처리되는 개인정보 항목 기재
- ※ 주소, 수급자주소, 자택주소, 자택번지 등과 같이 유사한 항목이 있는 경우에도 '주소'로 대표화하지 않고, 가급적 구분하여 상세히 기재(단, 명칭만 다르고 의미가 같은 경우에는 용어를 1개로 통일하여 기재)
- 개인정보 항목 기재 시 업무처리를 위해 필수 정보인지 선택정보인지 여부를 명확히 알 수 있도록 '필수', '선택' 항목 구분 표기

4) 주관부서

- 해당 개인정보 처리 업무를 주관하는 부서명 기재
- ※ 여러 부서가 공동으로 주관할 경우 모두 기재

5) 개인정보 건수

- 처리되는 개인정보 건수 기재

※ 여러 개인정보가 혼재하여 건수가 상이한 경우, 가장 많은 정보를 기준으로 기재하며, 고유식별정보가 포함된 경우, 건수 뒤에 '()' 후 고유식별정보의 개수를 추가 기재

※ 동일한 정보주체에 대한 정보가 중복되어 존재할 경우, 중복을 제거한 건수 기재

※ 신규 사업의 경우, 향후 1년 내에 예상되는 건수를 입력

6) 개인정보 영향도

- 처리 개인정보의 중요도에 따라 영향도를 산정

※ 대상사업(대상시스템)의 개인정보 처리업무, 처리되는 개인정보현황, 개인정보 항목의 조합수준에 따라 영향도를 산정하고, 자산(평가업무) 가치를 측정하여 '개인정보 영향도'를 작성

평가업무명	처리목적	처리 개인정보	주관부서	개인정보 건수	개인정보영향도
...	...	...	...	...	...
회원가입	본인확인	생년월일	○○사업부	10만	3
	본인확인	이메일주소	○○사업부	10만	3
	...	...	...	...	...
상담업무	본인확인	성명	○○사업부	5천	3
	본인확인	생년월일	○○사업부	5천	3
	...	...	...	...	...
실업급여 관리	사용자 인증	비밀번호	○○사업부	3만	5
	실업급여 입금	계좌번호	○○사업부	3만	5
...	...	...	...	...	...

※ 업무단위(평가업무명)별로 처리 개인정보를 그룹핑하여 하나의 셀에 정리하고 해당업무에서 처리하는 개인 정보의 영향도 중 가장 높은 숫자를 입력 (아래 "개인정보 처리업무표 예시" 참고)

■ 개인정보 처리 업무표 예시 ■

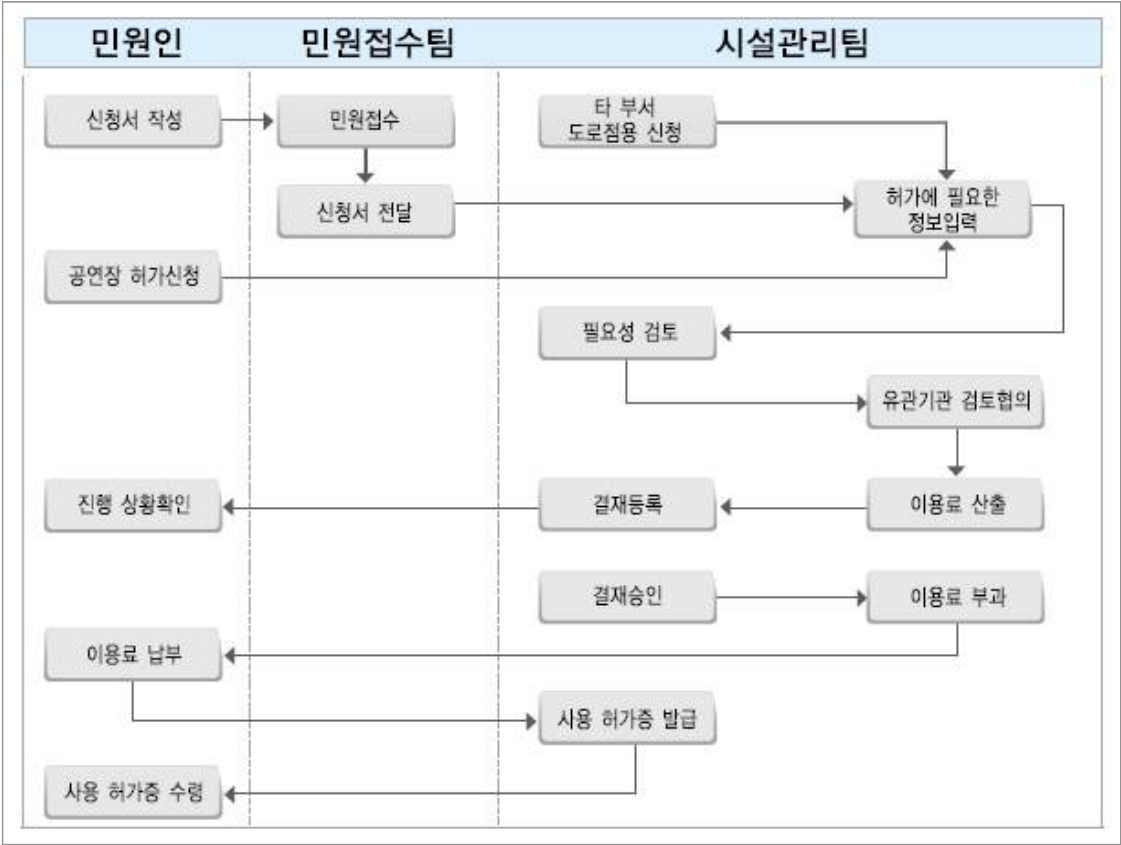
평가 업무명	처리 목적	처리 개인정보	주관 부서	개인정보 건수 (고유식별정보수)	개인정보 영향도
회원관리	홈페이지 회원가입, 본인확인, 정보제공 등 회원 서비스 제공	필수 : 성명, 생년월일, 전화번호, 이메일주소, ID, 비밀번호 선택 : 집주소, 집전화번호	민원팀	10만건 (0건)	5
상담업무	고객 문의 및 민원 응대	필수 : 성명, 전화번호, 상담내용	민원팀	5천건 (0건)	3
실업급여	실업급여 지급확인 및	필수 : 성명, 주민등록번호,	민원팀	3만건	5

평가 업무명	처리 목적	처리 개인정보	주관 부서	개인정보 건수 (고유식별정보수)	개인정보 영향도
관리	관련 절차 알림, 확인	계좌번호, 전화번호 선택 : 이메일주소		(3만건)	
...	...	...	...	...	...

3.2 개인정보 처리 업무흐름도 작성

- 평가대상 업무현황 분석을 통해 개인정보를 처리하는 업무 별로 ‘업무 흐름도’를 작성
 - 정형화된 별도서식은 없으며 영향평가 기관의 서식에 맞춰 작성하고, 사업분석시 활용한 참고자료에 업무흐름도가 있으면 기존에 작성된 것을 활용 가능
 - 개인정보 처리업무 흐름도는 해당업무를 수행하는 인력 및 부서 등을 함께 표시하고, 연계기관이 있는 경우에는 해당기관도 포함하여 작성

■ 개인정보 처리업무 흐름도(공용시설물 관리업무) 예시 ■



3.3. 개인정보 흐름표 작성

- 분석된 업무흐름을 기반으로 개인정보 처리업무별로 개인정보의 수집, 보유, 이용·제공, 파기로 구분하여 개인정보 흐름을 분류
- 개인정보 처리 단계별로 처리되는 개인정보 현황 및 처리 내역 등을 용이하게 식별할 수 있도록 개인정보 흐름표를 작성
 - 개인정보 흐름표에는 이전 단계에서 분류한 업무명을 기준으로 개인정보의 수집, 보유, 이용·제공, 파기에 이르는 Life-Cycle별 현황을 기재하여 개인정보 흐름을 한 눈에 이해할 수 있도록 작성



개인정보 생명주기(Life-Cycle)란?

o 개인정보 생명주기(Life-Cycle)란?

- 개인정보를 취득하여 활용하는 단계로써 통상적으로 수집, 보유, 이용·제공, 파기의 4단계로 구분
- **(수집)** 정보주체의 개인정보를 취득하는 단계로써, 통상적으로 웹사이트 회원 가입, 서면 신청서 작성, 민원 접수 등의 형태를 통해 이루어짐
- **(보유)** 수집한 개인정보를 보유하는 단계로써, 보유한 개인정보를 안전하게 관리하며 정보주체의 개인정보 열람·정정권리 등을 보장
- **(이용·제공)** 수집·저장한 개인정보를 업무적인 목적으로 이용하거나 수집한 공공기관 외의 제3의 기관에게 정보를 제공하는 행위
 - ※ 예를 들어, 특정 자격제도를 운영함에 있어 자격검정시험을 주관하는 기관과 자격 제도를 운영하는 기관이 상이한 경우에는 자격검정시험 주관 기관이 합격자 명단을 자격제도 운영기관과 연계하여 제공
- **(파기)** 수집 및 이용 목적이 달성된 개인정보를 파기하는 행위를 말함
 - ※ 예를 들어, 이용자가 웹사이트 회원을 탈퇴한 경우에는 특정한 사유가 없는 한 회원이 아닌 사람의 정보를 더 이상 보유하고 있을 필요가 없으므로 해당 정보를 파기해야 함

■ 개인정보 흐름표 양식 ■

<수집 흐름표>

평가 업무명 ¹⁾	수집					
	수집 항목 ²⁾	수집 경로 ³⁾	수집 대상 ⁴⁾	수집 주기 ⁵⁾	수집 담당자 ⁶⁾	수집 근거 ⁷⁾



수집 흐름표 양식 설명

※ 수집 흐름표에서 해당 사항이 없는 경우에는 기재하지 않음

- 1) **평가업무명** : 대상사업 중 어떤 업무와 관련하여 개인정보를 처리하는지 기재
- 2) **수집항목** : 수집하는 개인정보 항목을 구체적으로 기재
- 3) **수집경로** : 개인정보 수집방법이 온라인 또는 오프라인 등 해당 개인정보의 취득경로 기재
 - ※ 회원가입을 통한 수집경로는 웹사이트 회원가입, 온라인을 통한 가입, 서면신청서를 통한 오프라인 방식 등으로 구분
 - ※ 정보주체에게 직접 수집하거나 외부기관에 의해 제공받거나 연계하는 방법으로 수집
- 4) **수집대상** : 개인정보를 수집하는 대상인 정보주체의 유형을 기재
 - ※ 예를 들어, 인터넷 회원의 유형이 학생, 학부모 등으로 구분이 된다면 수집 대상도 "인터넷 회원(학생)", "인터넷 회원(학부모)"으로 나눠서 작성하여 가급적 수집하는 대상 유형을 구체적으로 기재
- 5) **수집주기** : 개인정보를 수집하는 주기를 기재
 - ※ 웹사이트 회원가입의 경우, 상시적으로 수집
 - ※ 외부기관으로부터 주기적으로 제공을 받거나, 대학 입시와 같이 특정 시기에만 수집되는 경우에는 해당 주기를 기재
- 6) **수집담당자** : 개인정보를 수집하는 부서 및 담당자 기재
- 7) **수집근거** : 수집목적에 따른 법률근거 및 사용자 동의획득 여부 기재
 - ※ 법률에 근거한 수집일 경우 법률 조항을 구체적으로 표시

■ 개인정보 흐름표 양식 ■

<보유·이용 흐름표>

평가 업무명 ¹⁾	보유·이용							
	보유 형태 ²⁾	암호화 항목 ³⁾	민원 처리			통계 관리		
			이용 목적 ⁴⁾	개인정보 취급자 ⁵⁾	이용 방법 ⁶⁾	이용 목적 ⁴⁾	개인정보 취급자 ⁵⁾	이용 방법 ⁶⁾



보유·이용 흐름표 설명

※ 보유·이용 흐름표에서 해당 사항이 없는 경우에는 기재하지 않음

1) 평가업무명 : 수집 흐름표와 동일

2) 보유 형태 : 수집한 개인정보를 보유하는 장소 및 형태를 기재

※ 수집한 개인정보는 시스템을 통해 DB에 저장하고, 신청서 등은 캐비넷 등에 보관

3) 암호화 항목 : 개인정보 저장 시 암호화하는 개인정보 항목을 기재

※ 수집한 개인정보를 DB에 저장할 때 '보유 시 암호화 항목'에 해당하고, 신청서 등 다른 매체 보유는 암호화 항목에서 제외

※ 일방향 암호화 되어 있는 경우에는 '()' 후 일방향 암호화하였음을 표기

4) 이용 목적 : 개인정보를 이용하는 목적 기재

5) 개인정보취급자 : 수집한 개인정보를 처리하는 부서 및 사용자 기재

6) 이용 방법 : 개인정보취급자가 개인정보를 이용하는 방법 기재

※ 이용 목적 및 취급자 현황은 개인정보 이용 현황에 따라 복수로 기재

■ 개인정보 흐름표 양식 ■

<제공·파기 흐름표>

평가 업무명 ¹⁾	제공								파기			
	제공 목적 ²⁾	제공자 ³⁾	수신자 ⁴⁾	제공 정보 ⁵⁾	제공 방법 ⁶⁾	제공 주기 ⁷⁾	암호화 여부 ⁸⁾	제공 근거 ⁹⁾	보관 기간 ¹⁰⁾	파기 담당자 ¹¹⁾	파기 절차 ¹²⁾	분리 보관 여부 ¹³⁾



제공·파기 흐름표 설명

※ 제공·파기 흐름표에서 해당 사항이 없는 경우에는 기재하지 않음

- 1) 평가업무명 : 수집 흐름표와 동일
- 2) 제공 목적 : 개인정보를 제공하는 목적을 상세히 기재
- 3) 제공자 : 개인정보를 제공하는 부서 및 관련 담당자 기재
- 4) 수신자 : 개인정보를 제공받는 타 기관, 시스템명 기재
- 5) 제공 정보 : 제공하는 상세 개인정보 항목을 기재
- 6) 제공 방법 : 개인정보 제공 시 타 기관에 제공하는 방식 및 시스템 연계 시 연계 방식 기재
- 7) 제공 주기 : 제공하는 개인정보 주기를 기재
- 8) 암호화 여부 : 정보 제공 시 제공 정보 암호화 여부 및 전송 시 암호화 여부 기재
※ 해당사항이 없는 경우에는 기재하지 않음
- 9) 제공 근거 : 개인정보를 제공하는 법적 근거 및 사유 기재
※ 법률에 근거한 제공일 경우 법률 조항을 구체적으로 표시
- 10) 보유기간 : 개인정보를 수집한 후 파기하기 전까지의 보관기간 명시
※ 보관기간은 정확한 기한이 있을 경우, 1년, 10년과 같이 표기하고, 정확한 기한이 없을 경우, '웹사이트 회원 탈퇴 시까지' 등과 같이 보유 기간 산정 원칙을 명시
- 11) 파기담당자 : 개인정보를 파기하는 부서 및 담당자
- 12) 파기 절차 : 파기가 결정된 개인정보에 대해 파기주기와 파기방법 기재
- 13) 분리 보관 여부 : 법령 등에 따라 개인정보를 파기하지 않고 보관하는 경우, 보존DB 등을 구성하여 다른 개인정보와 분리 저장·관리하는지 기재 (개인정보 보호법 제21조 제3항 참조)

■ 개인정보 흐름표(민원처리업무) 예시 ■

<수집 흐름표>

평가 업무명 ¹⁾	수집					
	수집 항목 ²⁾	수집 경로 ³⁾	수집 대상 ⁴⁾	수집 주기 ⁵⁾	수집 담당자 ⁶⁾	수집 근거 ⁷⁾
민원 처리	(필수) 성명, 주민등록번호, 전화번호, 이메일 주소, 민원 내용 (선택) 집전화번호	온라인 (홈페이지)	민원인	상시	-	이용자 동의/ OO법제O조O항 (주민등록번호)
		오프라인 (민원신청서 작성)	민원인	상시	안내창구 담당자	이용자 동의/ OO법제O조O항 (주민등록번호)

<보유·이용 흐름표>

평가 업무명 ¹⁾	보유·이용							
	보유 형태 ²⁾	암호화 항목 ³⁾	민원 처리			통계 관리		
			이용 목적 ⁴⁾	개인정보 취급자 ⁵⁾	이용 방법 ⁶⁾	이용 목적 ⁴⁾	개인정보 취급자 ⁵⁾	이용 방법 ⁶⁾
민원 처리	Web DB	주민등록번호, 비밀번호 (일방향)	민원 처리 및 결과 관리	민원처리 담당자, 민원 관련 업무 담당자	관리자 홈페이지의 민원처리 화면 접속	민원 현황 조회	통계 담당자	관리자 홈페이지의 통계관리 화면 접속
	민원 DB	주민등록번호, 비밀번호 (일방향)						
	캐비넷 (신청서류철)	-						

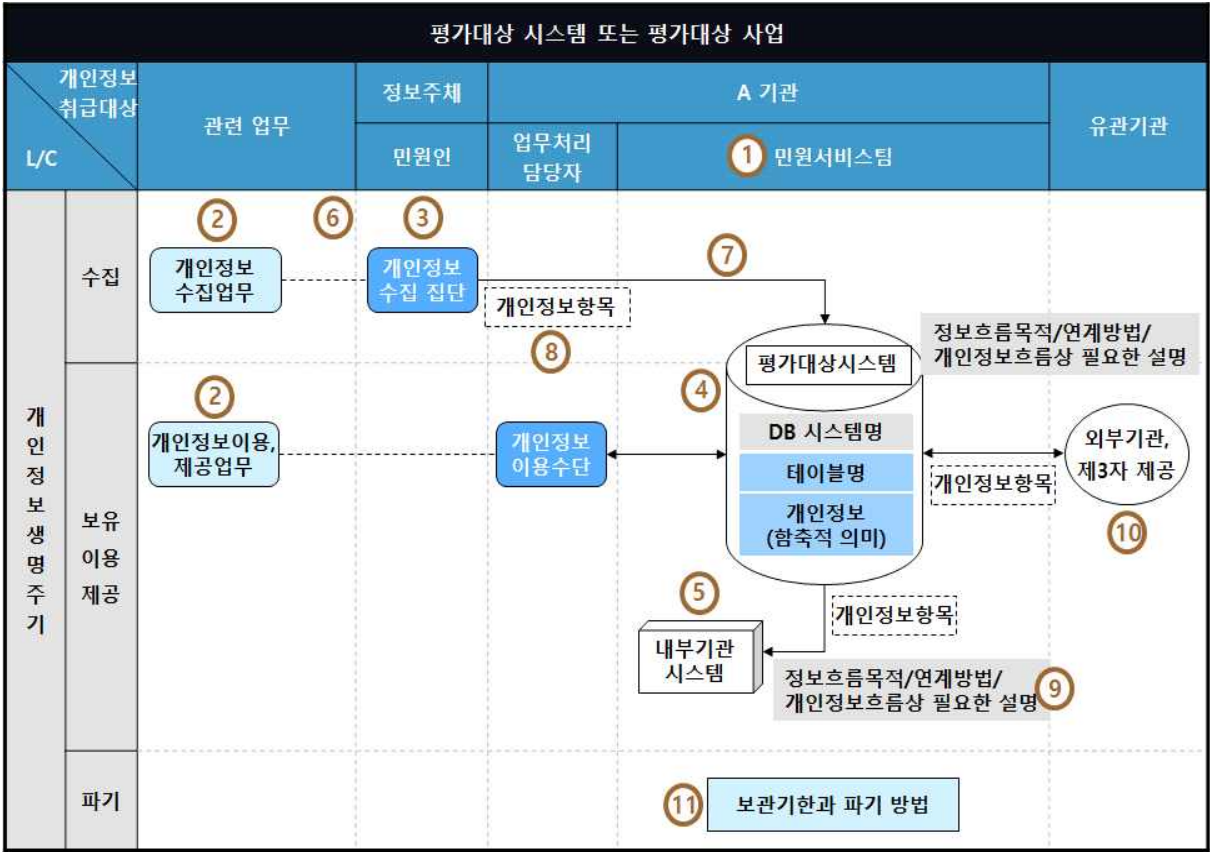
<제공·파기 흐름표>

평가 업무명 ¹⁾	제공								파기			
	제공 목적 ²⁾	제공 자 ³⁾	수신 자 ⁴⁾	제공 정보 ⁵⁾	제공 방법 ⁶⁾	제공 주기 ⁷⁾	암호화 여부 ⁸⁾	제공 근거 ⁹⁾	보관 기간 ¹⁰⁾	파기 담당자 ¹¹⁾	파기 절차 ¹²⁾	분리 보관 여부 ¹³⁾
민원 처리	민원 처리 실적 집계	통계 담당 자	OO 도청	민원인 성명, 민원 접수 내용, 처리 결과	실시간 DB 연동	상시	통신 구간 암호화 (VPN)	전자 정부 법 시행 령 OO조	민원 처리 완료 후 1년	DB 관리자	일단위 DB 파기	별도 보존DB 구성
									민원DB 입력 후 스캔 후 파기	통계 담당자	주단위 문서 절단	-

3.4 개인정보 흐름도 작성

- 작성된 개인정보 흐름표를 기반으로 수집, 보유, 이용·제공, 파기되는 개인정보 처리단계 별로 흐름을 한 눈에 파악할 수 있도록 ‘개인정보 흐름도’를 작성
- 영향평가대상사업 또는 시스템전체의 개인정보 흐름을 총괄적으로 표현한 ‘총괄 개인정보 흐름도’를 작성하고 개별업무별로 ‘업무별 개인정보 흐름도’를 함께 작성

■ 총괄 개인정보 흐름도 범례 ■





총괄 개인정보 흐름도 범례 설명

○ 총괄 개인정보 흐름도 작성 방법

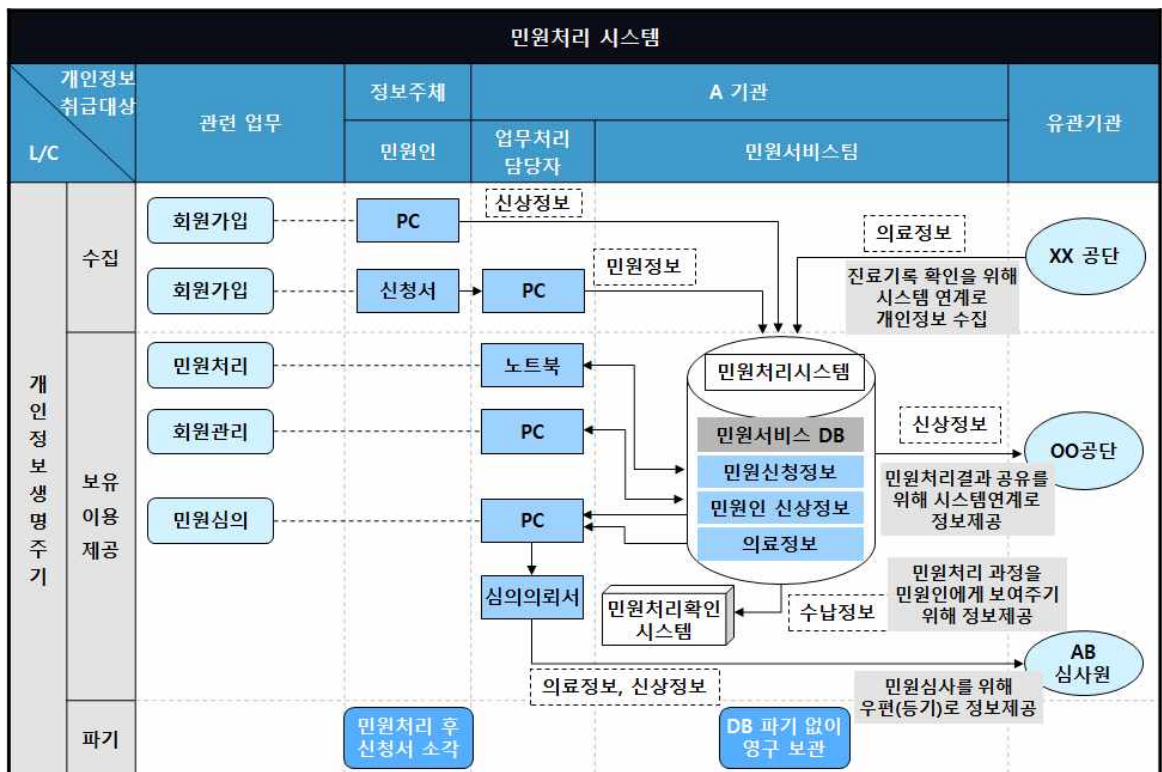
- ① 개인정보취급자(부서)를 정리하여 흐름도 상단에 기술
※ 취급부서 및 취급자는 필요에 따라 확장
- ② 개인정보 처리(수집, 보유, 이용·제공 파기)업무 기술
※ 업무에 따라 흐름도를 분리해야 할 경우, 각각 나누어 작성 가능
- ③ 각 업무에서 개인정보를 처리하는 수단 기술
※ 예 : PC, 신청서, 노트북, 전화, 대면, 의료기구 등
- ④ 개인정보를 보유하는 DB시스템을 표현하며 평가대상 시스템, DB명, 테이블명 또는 처리하는 개인정보의 함축적 의미를 가진 정보항목 기술
※ 예 : 신상정보(이름, 주민등록번호, 주소, 전화번호 등), 의료정보(혈압, 진단내용 등)
- ⑤ 평가대상기관 내부시스템과 연계하여 이용할 경우, 시스템명 기재
- ⑥ 개인정보 수집 시 수집하는 방법을 점선과 실선으로 표시
※ 온라인은 실선으로 하며, 오프라인으로 개인정보 흐름이 발생할 경우, 점선으로 구분
- ⑦ 개인정보 처리과정에서 정보의 흐름방향을 화살표로 연결
- ⑧ 개인정보 흐름을 표시한 화살표 상에 개인정보 항목 기술
- ⑨ 개인정보 흐름 목적/연계방식 등 개인정보 흐름파악에 필요한 설명을 간략히 기술
- ⑩ 개인정보 외부제공의 경우는 외부기관명 또는 외부업체명을 기재하고 제공방식, 제공하는 개인정보 항목 기술
※ 제공방식 : 시스템 연계(VPN, EAI 등), 우편(등기), 인편, Fax, 이메일 등
- ⑪ 개인정보의 보관기한과 파기 방법 기술

○ 민원처리시스템에 대한 총괄 개인정보 흐름도 예시

- 개인정보 흐름도 좌측은 수집, 보유, 이용·제공 파기와 관련한 개인정보 생명주기 기입
- 개인정보 흐름도 상단은 개인정보 처리업무를 기재하고, 개인정보취급자, 담당부서, 정보주체 등 기입하며 외부기관에 제공할 경우에는 관련한 유관기관명도 기재
- 개인정보 흐름도 본문은 처리업무, 사용매체와 수집한 개인정보를 처리할 때 관련한 IT시스템을 표시하고 각 요소들 간의 이동 시 전송되는 개인정보 항목을 기재

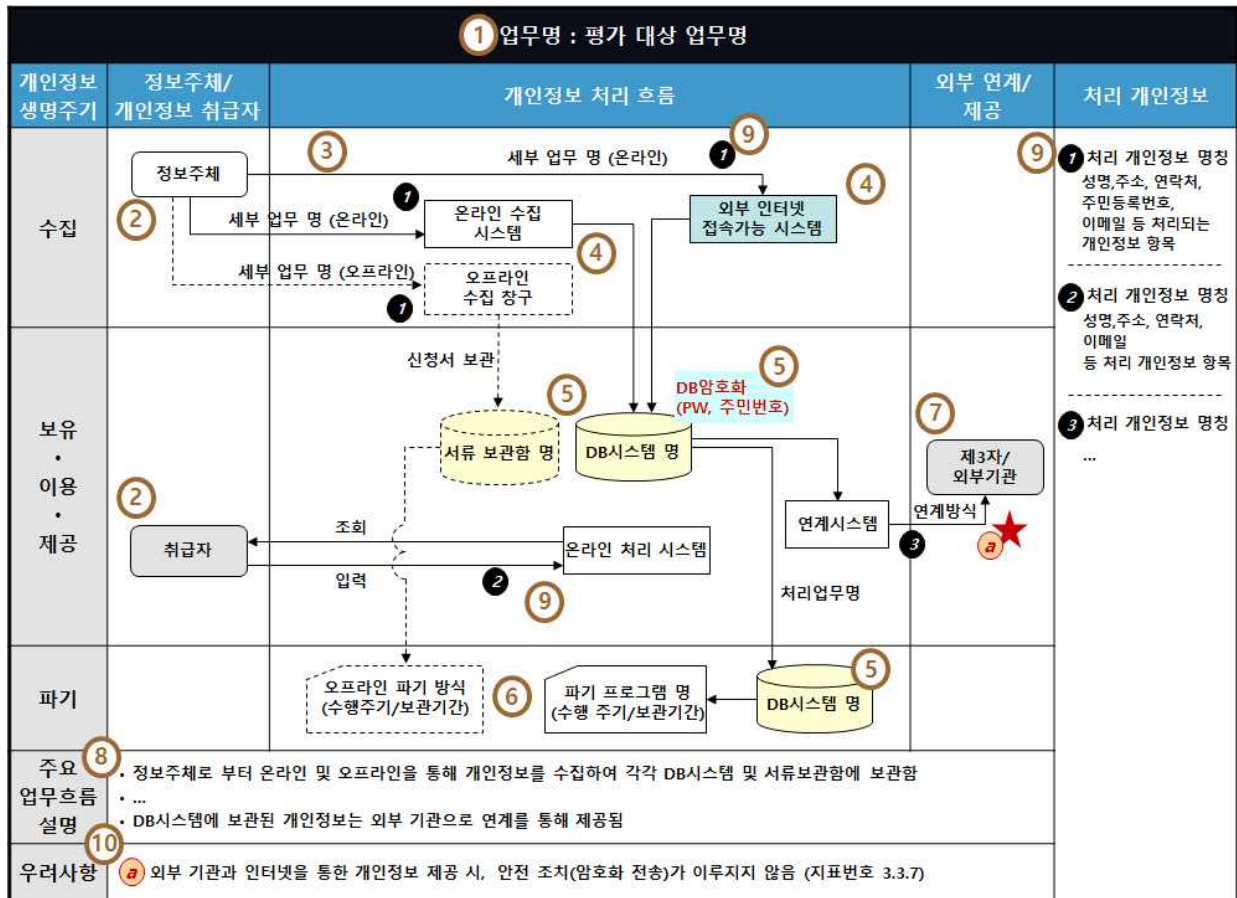
※ 총괄 개인정보 흐름도는 본 수행안내서에서 제시한 범례 및 형태를 반드시 따를 필요는 없으며, 각 영향평가기관의 방법론에 따라 다르게 표현될 수 있음

■ 민원처리시스템 총괄 개인정보 흐름도 예시 ■



○ 업무별 개인정보 흐름도는 아래 범례를 참고하여 작성

■ 업무별 개인정보 흐름도 범례 ■



업무별 개인정보 흐름도 범례 설명

○ 업무별 개인정보 흐름도 작성 방법

- ① 평가 대상 업무명을 알기 쉽게 정의하여 흐름도 상단에 기술
- ② 정보주체 및 취급자를 식별하여 구분하여 표시
※ 예 : 정보주체는 흰색 바탕, 취급자는 회색 바탕 도형 사용
- ③ 개인정보의 흐름을 간략한 세부업무 설명과 함께 점선과 실선으로 표시하고 암호화 여부를 표시
※ 온라인 흐름은 실선으로 하며, 오프라인으로 개인정보 흐름이 발생할 경우, 점선으로 구분
※ 암호화 된 수단을 사용하는 경우, 선을 붉은 색으로 굵게 표시
- ④ 개인정보를 처리하는 수단을 온라인 및 오프라인으로 구분하여 표시
※ 온라인은 실선으로 하며, 오프라인으로 개인정보 흐름이 발생할 경우 점선으로 구분
※ 외부 인터넷에서 접속 가능한 시스템의 경우, 내부 시스템과 다른 색으로 구분

- ⑤ 개인정보를 저장하는 보관소를 대표하는 명칭으로 표기하되 DB명, 파일명 또는 서류함 등과 같이 보관 방식에 따라 적절하게 용어를 선택하여 표시
 - ※ 캐비닛 등 오프라인 저장소의 경우 점선으로 구분
 - ※ 암호화 보관되는 정보의 경우 암호화 항목을 박스로 별도 표시
- ⑥ 파기방식을 파기수행 주기와 함께 온라인 및 오프라인으로 구분하여 표시
- ⑦ 개인정보 외부제공의 경우는 외부기관명(또는 외부시스템) 또는 외부 업체명을 기재하고 제공방식 및 제공하는 개인정보 항목을 기술
 - ※ 제공방식: 시스템연계(VPN, EAI 등), 우편(등기), 인편, Fax, 이메일 등
- ⑧ 평가대상 업무에 대한 흐름을 간략하게 설명하여 서술
- ⑨ 개인정보 흐름 상 전달되는 개인정보 항목을 숫자로 구분하여 도표에 표시하고 흐름도 우측에 전달되는 세부 개인정보 항목을 표시
- ⑩ 개인정보 흐름을 통해 나타난 주요 문제점 및 관련 지표번호를 요약하여 기술

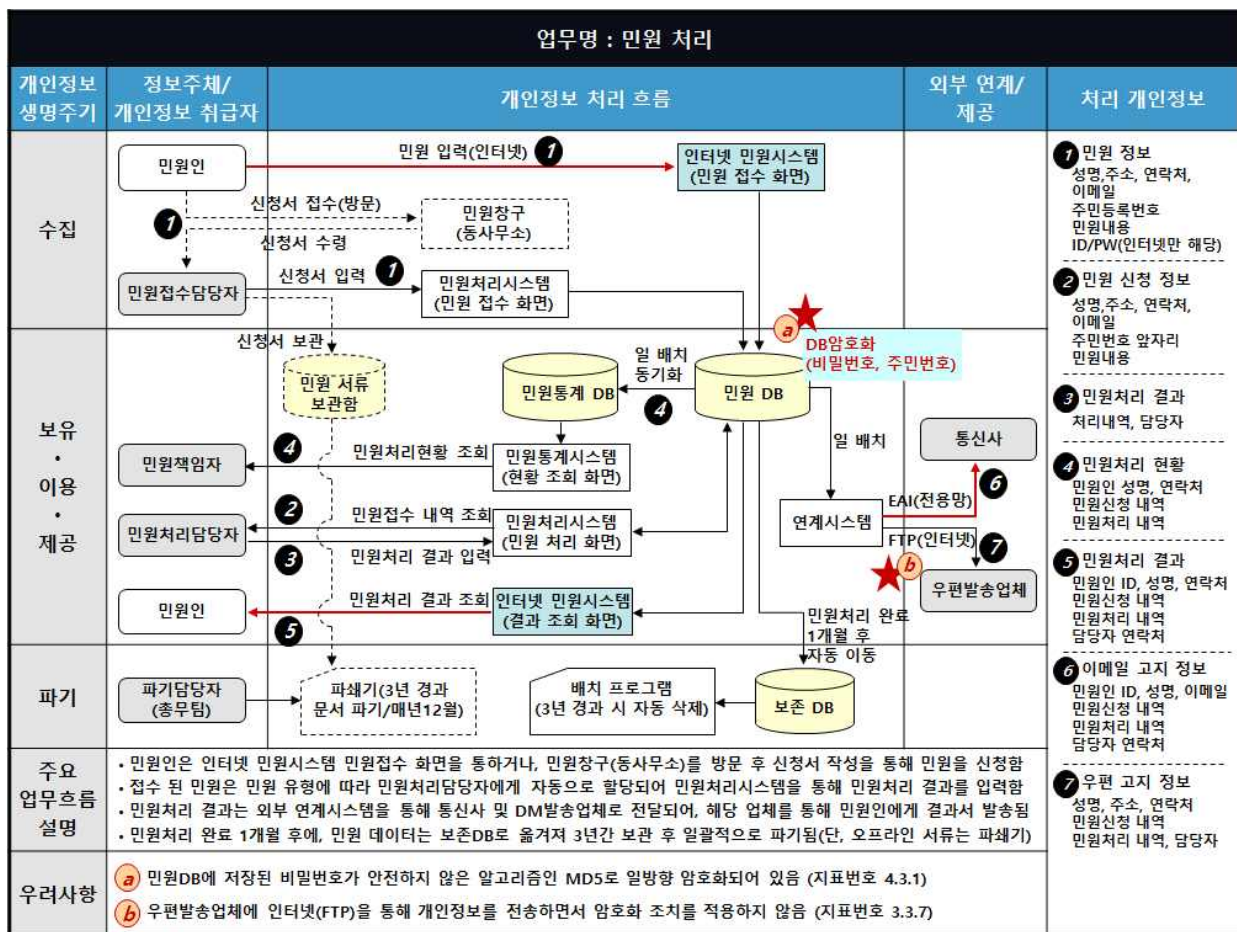
○ 민원처리 업무에 대한 개인정보 흐름도 예시

- 개인정보 흐름도 좌측에 수집, 보유, 이용·제공, 파기와 관련한 개인정보 생명주기를 기입

- 개인정보 흐름도 우측에 처리 개인정보를 기재하고 개인정보 흐름에서 처리되는 개인정보 항목을 명확히 기입
- 개인정보 흐름도 상단에는 업무명을 기재하고, 개인정보처리자 및 담당부서, 정보주체 등을 기입하며 외부연계나 제공이 발생할 경우 관련기관명도 기재
- 개인정보 흐름도 하단에는 주요 업무흐름설명 및 우려사항을 기재하고, 개인정보 흐름도에 대한 간략설명 및 예상되는 문제점을 기입
- 흐름분석 단계와 침해요인 분석단계와의 연결성 및 추적성을 확보하기 위하여 해당 우려사항과 관련된 영향평가 지표번호를 함께 기록

※ 업무별 개인정보 흐름도는 본 수행안내서에서 제시한 범례 및 형태를 반드시 따를 필요는 없으며, 각 영향평가기관의 방법론에 따라 다르게 표현 가능

■ 민원처리 업무 개인정보 흐름도 예시 ■



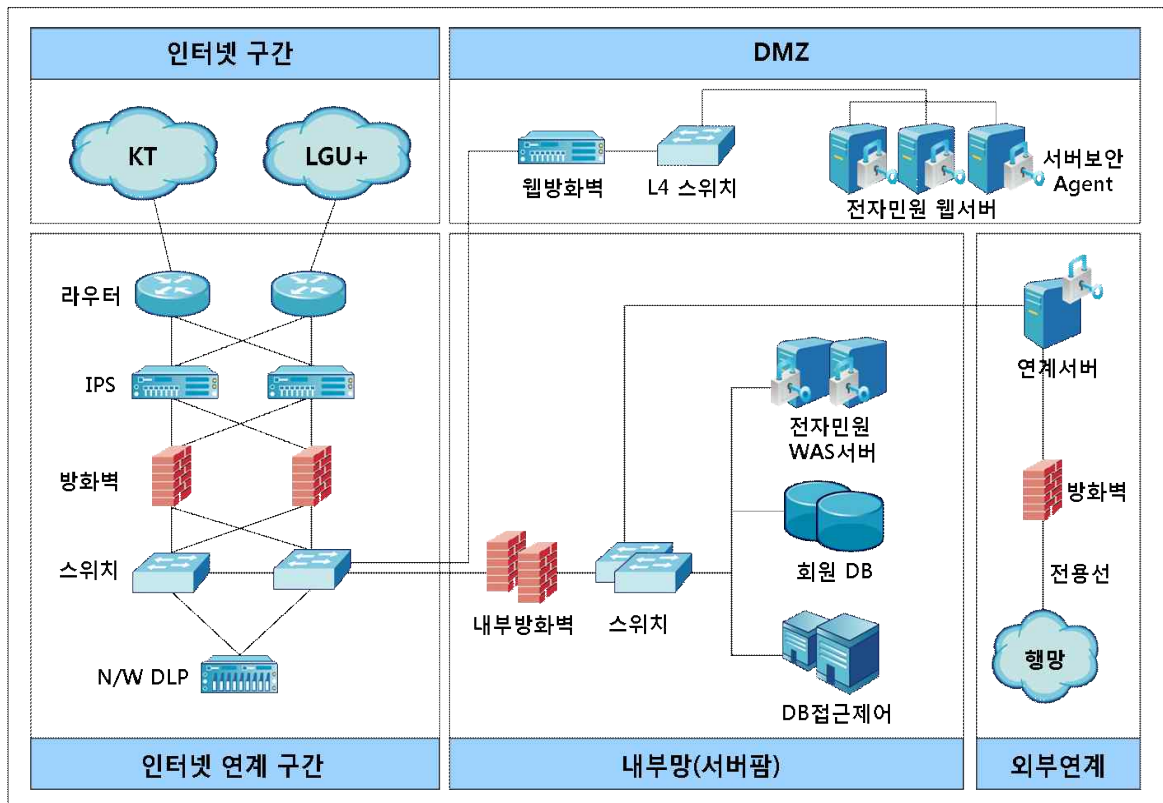
※ 각각의 평가대상 업무별로 별도의 상세 개인정보 흐름도가 작성되어야 함

3.5 정보시스템 구조도 및 정보보호 시스템 목록 작성

○ 개인정보 처리시스템과 내·외부 연계시스템 등 인프라의 구성을 파악

- 시스템 구조, 외부 연계 및 방화벽, 침입탐지시스템 및 전송데이터 암호화, DB 암호화 등 기술적·물리적 보안시스템 현황을 분석 가능하도록 상세히 작성
- 인터넷 구간, DMZ 구간, 외부 연계 구간, 내부망 영역 등 네트워크 성격에 따른 구분이 표시
 - ※ 네트워크 접근제어의 미흡, 서비스 거부 공격에 대한 방어, 네트워크 가용성 확보 미흡 등과 같이 시스템 설계상 내재된 개인정보 침해요인을 분석, 위험도 산정 등에 활용
- 시스템의 물리적 위치(자체 전산실, 통합전산센터 등), 관리 범위 등 영향평가 대상 시스템의 물리적·구조적 범위가 명확히 구분되도록 표시하고, 특히 서버, 데이터베이스 등 인프라 영역이 영향평가 대상 범위인지 분석하여 기록 필요
- 정보시스템 구조도 및 정보보호 시스템 목록은 보안이 중요하여 공개가 어렵다고 판단할 경우에는 비공개로 처리 가능
 - ※ 단, 비공개로 처리하더라도 시스템 구조 및 정보보호 현황 분석은 충실히 수행되어야 하며, 시스템 구조도 전체를 비공개로 처리하기 보다는 보안상 민감한 영역을 제외하거나 단순화하여 작성 필요

■ 정보시스템 구조도 예시 ■



- 개인정보 처리시스템에 대한 보호 대책의 적정성을 검토하고 효과적인 침해 요인 분석 및 위험도 산정이 가능하도록 '정보보호 시스템 목록'을 작성
 - 목적 및 용도, 시스템의 유형, 적용 솔루션명, 적용 대상 등에 대하여 기재

- 해당 정보보호 시스템이 적용된 대상 구간과 시스템의 사용자가 특정인으로 한정되는 경우 사용자 등을 기재
- 시스템이 영향평가사업 이전에 신규로 도입·적용되는 것인지, 기존에 운영 중인 정보보호 시스템이 확장 또는 변경되는 것인지 등에 대해서도 기재

■ 정보보호 시스템 목록 예시 ■

유형	적용 솔루션명	목적 및 용도	적용 대상	본 사업 범위 여부
방화벽	SuhoGod FW v4.0	- 인터넷과 내부 네트워크 분리 - DMZ 구성 및 접근통제 - 내부서버에 대한 접근 통제	- 인터넷 관문(이중화) - 내부 서버팜 앞단 (1)	기 운영 중
IPS	SafeZ IPS v3.5	- 인터넷에서의 네트워크 공격 탐지 및 차단	- 인터넷 관문(이중화)	기 운영 중
서버보안	SecuOS for UNIX	- 서버 계정관리, 접근통제, 이력 로깅	- UNIX 서버 전체 - Windows 계열서버 제외	O
DB 접근 제어	DB Security v2.0	- DB 계정 관리, 접근통제, 개인정보 접속기록 저장 등	- 홈페이지 회원DB - 상담DB - 민원서비스 DB	O
DB암호화	DB Boan v1.0	- 고유식별정보 등 중요 개인정보에 대한 DB암호화	- 홈페이지 회원DB - 민원서비스 DB	O
보안USB	S-USB Plus	- 개인정보파일 등을 USB 저장/전달 시 자동암호화 - USB 분실 통제	- 민원부서 사용자(200명)	O

4. 개인정보 침해요인 분석

목 표	개인정보의 흐름에 따른 개인정보 조치사항 및 계획 등을 파악하고 개인정보 침해 위험성 도출
개 요	① 평가기준 수립 및 개인정보보호 조치사항 파악을 위한 평가항목 작성 ② 자료 분석, 현장 및 시스템 실사, 담당자 인터뷰 등을 통해 개인정보보호 조치 현황 파악 ③ 파악한 조치 현황을 기반으로 개인정보 침해요인 도출 ④ 도출된 개인정보 침해요인에 대한 위험도 산정
수행주체	영향평가팀
참고자료	내부 정책자료, 외부 정책자료, 개인정보 영향도 등급표, 개인정보 처리업무표, 개인정보 흐름표, 개인정보 흐름도, 정보시스템 구조도, 정보보호시스템 현황
산 출 물	평가항목, 침해요인 목록, 위험도 산정결과, 개선방안 목록

4.1 평가항목 구성

○ 개인정보 침해요인 분석을 위한 평가항목은 5개 평가영역 25개 평가분야에 대하여 총 85개의 지표로 구성

- 단, '1. 대상기관 개인정보보호 관리체계' 평가영역은 1년 이내에 수행된 이전 영향평가를 통해 이미 평가를 수행한 경우 대상기관과의 협의를 거쳐 제외 가능

■ 영향평가 평가영역 및 평가분야 (「개인정보 영향평가에 관한 고시」 별표4) ■

평가영역	평가분야	세부분야
1. 대상기관 개인정보보호 관리체계	1.1 개인정보보호조직	개인정보 보호책임자의 지정
		개인정보 보호책임자 역할수행
	1.2 개인정보보호계획	내부관리계획 수립
		개인정보보호 연간계획 수립
	1.3 개인정보 침해대응	침해사고 신고방법 안내
		유출사고 대응
	1.4 정보주체 권리보장	정보주체 권리보장 절차 수립
		정보주체 권리보장 방법안내

2. 대상시스템의 개인정보보호 관리체계	2.1 개인정보취급자 관리	개인정보취급자 지정
		개인정보취급자 관리·감독
	2.2 개인정보파일 관리	개인정보파일 대장 관리
		개인정보파일 등록
	2.3 개인정보처리방침	개인정보처리방침의 공개
		개인정보처리방침의 작성
3. 개인정보 처리단계별 보호조치	3.1 수집	개인정보 수집의 적합성
		동의받는 방법의 적절성
	3.2 보유	보유기간 산정
	3.3 이용·제공	개인정보 제공의 적합성
		목적 외 이용·제공 제한
		제공시 안전성 확보
	3.4 위탁	위탁사실 공개
		위탁 계약
		수탁사 관리·감독
	3.5 파기	파기 계획 수립
		분리보관 계획 수립
		파기대장 작성
4. 대상시스템의 기술적 보호조치	4.1 접근권한 관리	계정 관리
		인증 관리
		권한 관리
	4.2 접근통제	접근통제 조치
		인터넷 홈페이지 보호조치
		업무용 모바일기기 보호조치
	4.3 개인정보의 암호화	저장 시 암호화
		전송 시 암호화
	4.4 접속기록의 보관 및 점검	접속기록 보관
		접속기록 점검
		접속기록 보관 및 백업
	4.5 악성프로그램 방지 등	백신 설치 및 운영
		보안업데이트 적용

	4.6 물리적 접근방지	출입통제 절차 수립
		반출·입 통제 절차 수립
	4.7 개인정보의 파기	안전한 파기
	4.8 기타 기술적 보호조치	개발환경 통제
		개인정보처리화면 보안
		출력 시 보호조치
	4.9 개인정보처리구역보호	보호구역 지정
5. 특정IT 기술 활용 시 개인정보보호	5.1 CCTV	CCTV 설치 시 의견수렴
		CCTV 설치 안내
		CCTV 사용 제한
		CCTV 설치 및 관리에 대한 위탁
	5.2 RFID	RFID 이용자 안내
		RFID 태그부착 및 제거
	5.3 바이오정보	원본정보 보관 시 보호조치
	5.4 위치정보	개인위치정보 수집 동의
		개인위치정보 제공 시 안내사항

○ 평가항목은 침해사고 사례, 법제도의 변화, 대상기관 및 대상사업의 특성 등에 따라 추가·삭제·변경 등 탄력적으로 구성하여 사용할 필요가 있으며, 특히 개인정보보호 관련 법령·고시가 개정된 경우 해당 사항에 대해서는 반드시 평가항목에 반영하여 점검하여야 함

- (예시1) CCTV 관제센터에 대한 영향평가 시, '5.1 CCTV' 분야의 평가항목에 영상정보 마스킹, 영상정보 암호화 등의 영상정보 보호 조치 평가 항목 추가
- (예시2) 「개인정보의 안전성 확보조치 기준」 고시가 개정된 경우, '4. 대상시스템의 기술적 보호조치' 분야의 평가항목에 개정된 고시 내용을 반영하여 평가항목을 추가 및 변경

※ 법규는 수시로 개정되므로 평가시점에 반드시 최신 법규를 확인하여 평가항목에 반영하여야 함.
또한 법규 유효기간 중이거나 입법 예고인 상태 등에 따라 법규 시행이 확정되었거나 또는 시행 가능성이 높은 경우에는 선제적으로 평가항목에 반영할 필요가 있음

○ 「개인정보의 안전성 확보조치 기준」과 관련된 평가항목은 대상기관의 유형에 따라 필수·선택 여부가 결정되므로, 대상기관이 어떤 유형에 속하는지 분석 필요

- 10만명 이상의 정보주체에 관한 개인정보를 보유한 공공기관은 유형3에 해당하며, 10만명 미만의 정보주체에 관한 개인정보를 보유한 공공기관은 유형2에 해당함

[개인정보처리자 유형 및 개인정보 보유량에 따른 안전조치 적용 유형]

구 분	1만명 미만	1만명~10만명 미만	10만명~100만명 미만	100만명 이상
공공기관	유형2(표준)		유형3(강화)	
대기업				
중견기업				
중소기업	유형2(표준)			유형3(강화)
소상공인	유형1(완화)	유형2(표준)		
개인				
단체	유형1(완화)	유형2(표준)		유형3(강화)

- 대상기관이 어느 유형에 해당하는지에 대한 입증책임은 당해 대상기관이 부담하게 됨
- 개인정보 보유량은 영향평가의 대상이 되는 개인정보파일만이 아니라, 대상기관이 보유한 전체 개인정보 보유량을 기준으로 산정해야 함
- 영향평가서 내에 대상기관이 어떤 유형에 속하는지 명확히 정의한 후, 이를 근거로 평가항목 별로 필수와 선택 여부를 지정하여 평가를 수행할 필요가 있음

4.2. 개인정보 보호조치 현황파악

- 대상 사업의 특성에 맞게 작성된 평가항목을 바탕으로 자료검토, 시스템 점검, 현장실사, 인터뷰 등을 통해 개인정보보호 조치사항을 파악하여 분석

■ 평가항목 예시 ■

세부분야	개인정보보호 책임자의 지정				
질의문 코드	질의문	이행	부분이행	미이행	해당없음
1.1.1	○ 개인정보 보호책임자를 법률기준에 따라 지정하고 있습니까?		○		
평가 예시	○ 이행 : 개인정보 보호책임자를 법률 기준에 따라 지정하고, 지침 또는 직무기술서, 임명장 등 관련 문서 등을 통해 개인정보 보호책임자의 지정사실을 알리고 있는 경우 ○ 부분 이행 : 개인정보 보호책임자가 지정되어 있으나 법률기준을 만족하지 못하거나, 지정사실을 전체 직원이 알 수 있도록 공식화하지 않은 경우				
평가근거 및 의견	○ 평가대상기관인 △△△ 기관은 4급 이상의 공무원 자격 기준을 만족하고 있는 자를 개인정보 보호책임자로 지정하여야 하나, 현재 5급 공무원이 책임자로 지정되어 있음				

- 질의문 : 평가 항목에 따른 체크리스트
- 확 인 : 평가기준은 다음과 같음

평가기준	내용
이행 (Y)	정상적으로 조치되어 있음 - 점검항목에 대해 실제 이행, 적용하고 있고 그 사실에 대한 정확한 근거(문서)가 존재하는 경우
부분이행 (P)	부분적으로 조치되어 있음 - 점검항목에 대해 이행, 적용하고 있으나 정확한 근거(문서) 없이 인터뷰에 의하여 계획으로만 되어 있거나 이행, 적용여부의 확인이 어려운 경우
미이행 (N)	해당사항에 대해 조치된 바 없음 - 점검항목에 대해 실제 이행, 적용하지 않고 있거나 계획도 없는 경우
해당없음 (N/A)	해당사항 없음 - 점검항목이 대상사업과 무관한 경우

※ Y : Yes, P : Partial, N : No, N/A : Not Applicable

- 평가 근거 및 의견 : '확인' 부분에 이행, 부분이행, 미이행, 해당없음이라고 평가한 상세근거 및 사유를 기재하고, 관련 규정이 있는 경우 근거 조항 기재
- 항목 설명 : 평가항목의 추가적인 설명 및 용어 설명 제시
- 평가 예시 : 평가 질의문의 '확인'란에 해당하는 이행(Y), 부분이행(P), 미이행(N), 해당 없음(N/A)을 판단하는 예시 제시
- 관련 법령 및 근거 : 평가 질의문에 관한 내용을 규정하는 법, 규정 등 관련 문서 제시

지표평가 시 주의사항

본 「개인정보 영향평가 수행안내서」 부록3 “개인정보 영향평가 항목(평가표)”을 참고하여 평가를 수행하되, 대상 기관 및 대상 시스템의 특성과 평가시점에서의 최신 IT기술 및 보안위협 동향, 법 규정 변경 사항 등을 반영하여 평가를 수행하여야 한다. 특히, 개인정보보호법 등 관련 법 규정은 수시로 개정되는 경우가 많으므로 반드시 최신 법률을 기반으로 평가가 수행될 수 있도록 하여야 한다.

○ 고유식별정보(주민등록번호 제외)가 내부망에 저장될 때에는 영향평가 또는 위험도분석 결과에 따라 암호화 여부의 결정이 가능

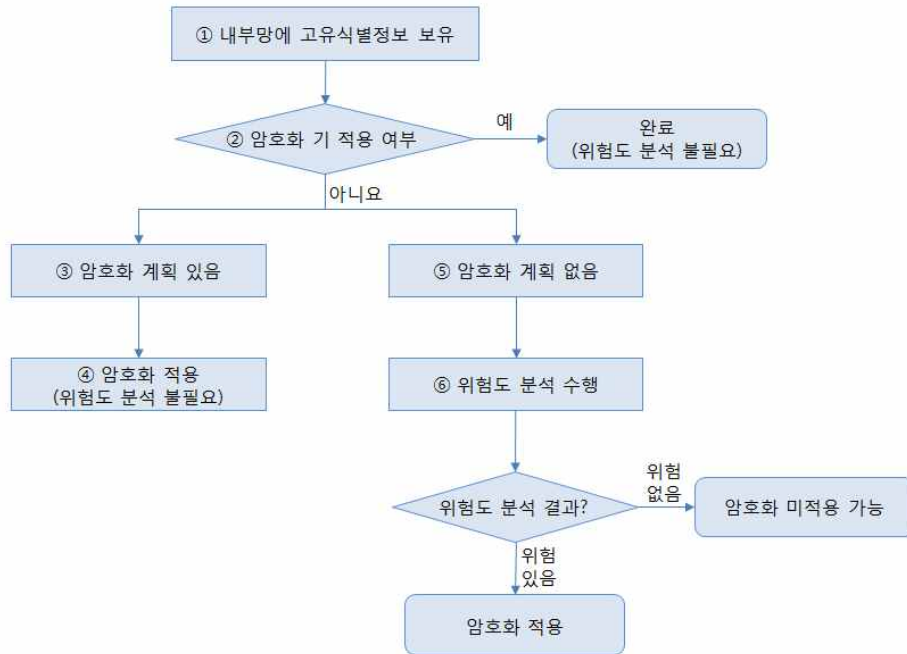
- 고유식별정보 암호화 적용 계획이 있거나 적용되었다면 위험도 분석 불필요
- 주민등록번호는 법제24조의2제2항에 따라 위험도 분석 결과에 상관없이 저장시 암호화 필요

※ 개인정보보호법 시행령 제21조의2에 따라 100만명 미만의 정보주체에 관한 주민등록번호를 보관하는 경우 2017년1월1일 이전까지, 100만명 이상의 정보주체에 관한 주민등록번호를 보관하는 경우 2018년1월1일 이전까지 암호화 조치 적용



고유식별정보 암호화 적용여부 판단 절차

- 고유식별정보는 「개인정보 보호법」 제24조, 제29조 및 「개인정보의 안전성 확보조치 기준」 고시에 따라 암호화 적용 필요
- 단 내부망에 고유식별정보(주민등록번호 제외)를 저장하는 경우, 「위험도 분석」 결과에 따라 암호화의 적용여부 및 적용범위를 정하여 시행 가능



- 외부망 또는 DMZ에 고유식별정보를 저장할 경우 필수적으로 암호화를 적용하여야 함. 다만 내부망에 고유식별정보를 저장할 경우 영향평가 또는 위험도 분석에 근거하여 암호화 적용 여부 및 적용범위를 결정 가능
- 내부망에 저장된 고유식별정보가 암호화 되어 있지 않을 경우 암호화 계획 수립 여부 검토
- 암호화 계획이 수립되어 있을 경우 별도 위험도 분석 실시 불필요
- 암호화 계획에 따라 암호화 적용
- 암호화 계획이 없을 경우 위험도 분석 수행 필요하며, 영향평가에 포함하여 수행하거나 공공기관 자체적으로 수행 가능
- 「개인정보 위험도 분석기준」에 따라 위험도 분석 수행 후 고유식별정보에 대한 암호화 적용 여부 최종 결정

※ '개인정보 위험도 분석 기준 및 해설서' 참고

※ 단, 주민등록번호는 위험도 분석 결과와 상관없이 암호화 (시행령 제21조의2 참조)

○ 개인정보 취급업무 및 개인정보 흐름이 다수 존재하는 경우에는 각 흐름별로 관련된 평가항목에 대하여 각각 평가 수행

- 개인정보 흐름분석 결과와 침해요인 분석 결과 간의 연계성 확보 필요

○ 평가항목 별 평가 결과는 상세한 근거와 함께 정리하여 기재

- 부분이행(P), 미이행(N) 뿐 아니라 이행(Y), 해당없음(N/A)으로 평가된 항목에 대해서도 평가 결과와 근거를 상세한 사유 및 증거와 함께 제시
- 평가 사유 및 증적은 단순히 담당자 인터뷰 결과만을 근거로 제시하는 것은 지양하며 정확한 사실에 기반하여 관련 문서명, 증거사진, 화면캡처 등을 제시

■ 평가항목별 결과 작성 예시(1) ■

질의문 코드	질의문	확인			
4.3.3	○ 고유식별정보, 바이오정보, 비밀번호 등 중요 개인정보를 정보통신망을 통해 송·수신하거나 보조저장매체 등을 통해 전달하는 경우 암호화하도록 계획하고 있습니까?	이행	부분이행	미이행	해당없음
				○	
평가 근거 및 의견	- 000 웹사이트에 보안서버(SSL)가 적용되어 있지 않아 인터넷 회원의 인증정보(ID/PW), 고유식별정보 등 개인정보가 인터넷 구간에서 평문으로 전송되고 있음 [회원 로그인시 전송 데이터 캡처 결과 - ID/PW 평문 노출] 				
항목 설명	○ 웹사이트에서 ID/PW와 같은 인증정보, 고유식별정보 등 중요 개인정보를 전송하는 경우, 네트워크 도청을 통한 개인정보 노출을 방지하기 위하여 인증정보를 포함한 개인정보에 대하여 암호화하여 전송하도록 함				
평가 예시	○ 이행 : 웹사이트에 보안서버(SSL)를 적용하여 인증정보, 고유식별정보 등 개인정보를 암호화하여 전송함 ○ 부분 이행 : 웹사이트에 보안서버(SSL)를 적용하여 개인정보를 암호화하여 전송하고 있으나, 비밀번호 변경 등 일부 화면에서 암호화 전송이 누락됨				
관련 법률 및 문서	○ 개인정보의 안전성 확보조치 기준 고시 제7조(개인정보의 암호화)				

■ 평가항목 별 결과 작성 예시(2) ■

질의문 코드	질의문	확인			
		이행	부분이행	미이행	해당없음
4.3.1	○ 고유식별정보, 바이오정보, 비밀번호 등 중요 개인정보를 저장하는 경우, 안전한 방식으로 암호화 저장하도록 계획하고 있습니까?	이행	부분이행	미이행	해당없음
평가 근거 및 의견	- 상용 암호화 제품(000)을 도입하여 주민등록번호, 비밀번호에 대하여 안전한 알고리즘으로 암호화하여 저장하고 있음 ▶ 주민등록번호 : 양방향 암호화(ARIA-128 알고리즘) ▶ 비밀번호 : 일방향 암호화(SHA-256 알고리즘) 주민등록번호 암호화 주민번호 암호화 내역 하드카피 비밀번호 암호화 처리 내역 (SHA 256 방식)				
항목 설명	○ DB암호화는 서비스 실행에 많은 부하를 줄 수도 있으나 중요 개인정보의 경우 데이터 암호화 등의 대책을 수립하여 개인정보 유출 사고를 최대한 방지하도록 한다. ※ 고유식별정보 범위 : 주민등록번호, 여권번호, 운전면허번호 및 외국인등록번호 ※ 민감정보 범위 : 사상·신념, 노동조합·정당의 가입·탈퇴에 관한 정보 등 법률에서 정한 민감정보와 유전정보 및 범죄경력에 관한 정보				
평가 예시	○ 이행 : 중요 개인정보가 암호화되도록 화면설계서 등의 설계문서에서 확인할 수 있는 경우 ○ 부분이행 : 중요 개인정보가 암호화 되도록 화면설계서 등의 설계문서에서 확인할 수 있으나 일부 개인정보에 대해서만 적용하고 있는 경우				
관련 법률 및 문서	○ 개인정보 보호법 제24조(고유식별정보의 처리 제한) ○ 개인정보 보호법 제24조의2(주민등록번호 처리의 제한) ○ 개인정보 보호법 시행령 제21조의2(주민등록번호 암호화 적용 대상 등) ○ 개인정보의 안전성 확보조치 기준 고시 제7조(개인정보의 암호화)				

4.3 개인정보 침해요인 도출

- 개인정보 흐름 분석 및 개인정보보호 조치 현황에 대한 평가결과를 기반으로 개인정보 침해요인 분석
 - '이행(Y)' 및 '해당없음(N/A)'로 평가된 항목은 침해요인이 없는 것으로 판단
 - '미이행(N)' 및 '부분이행(P)'로 평가된 항목은 평가결과를 근거로 구체적인 침해요인 분석 및 도출 필요
- 침해요인은 유사 침해사고 사례, 대상시스템 및 업무특성 등을 반영하여 작성하고, 법률 위반 사항에 대해서는 별도로 표기 필요

■ 침해요인 작성 예시 ■

질의문 코드	질의문	평가근거 및 의견	개인정보 침해 요인	법적 준거성
4.3.3	○ 고유식별정보, 바이오정보, 비밀번호 등 중요 개인정보를 정보통신망을 통해 송수신 하거나 보조저장매체 등을 통해 전달하는 경우 암호화 하도록 계획하고 있습니까?	현 시스템 및 설계서 상에 고유식별정보 등 개인정보를 홈페이지 서버로 전송 시 암호화가 적용되어 있지 않음	스니핑 등 네트워크 도청을 통해 홈페이지 회원의 고유식별정보, 인증정보가 비인가자에게 유출될 우려가 있음	개인정보 안전성 확보조치 기준 고시 제7조 위반 (3,000만원 이하 과태료)

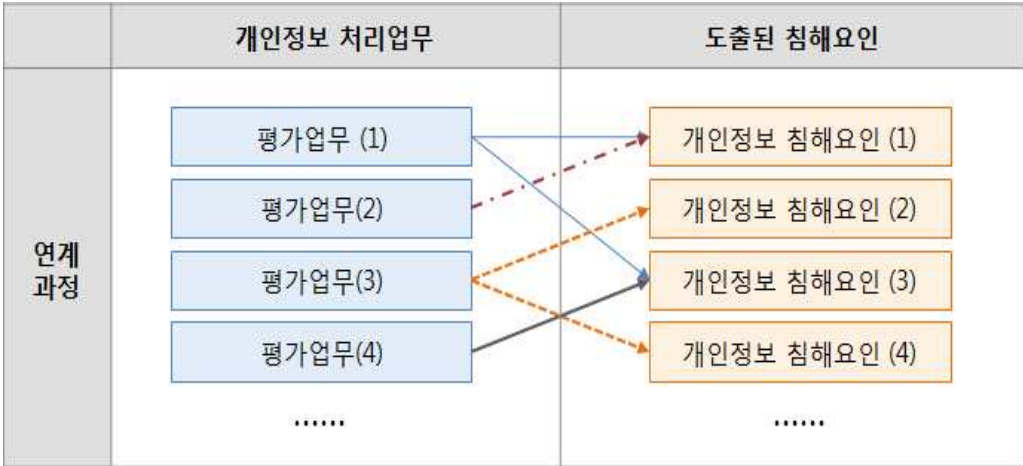
4.4 개인정보 위험도 산정

- 도출된 침해요인은 모두 개선하는 것이 원칙이나, 기관내 예산이 부족한 경우 등 불가피한 사유가 있는 경우에는 위험분석 결과에 따라 개선사항의 우선 순위를 정하여 선택적 조치 가능
 - ※ 단, 법적 의무사항은 필수적으로 조치 필요
- 위험도 산정방법은 아래에서 제시된 예시 외에도 위험에 대한 관점에 따라 다양하므로, 평가기관의 자체 위험분석 방법론을 활용하여 위험도를 산정
- 다만 위험도를 산정할 때에는 아래 사항을 고려
 - 위험도 산정 과정 및 결과는 합리적이고 납득 가능한 수준이어야 함
 - 위험도 산정값은 실질적인 위험의 크기를 대변할 수 있어야 함
 - 법적 준거성 등 개인정보보호 영역의 특성이 반영되어야 함

○ [위험도 산정 예시] 개인정보 영향도, 침해요인 발생가능성 및 법적 준거성에 따른 개인정보 위험도 산정 방법

- 개인정보 처리업무 내 개인정보의 조합수준, 등급 등에 따라 개인정보 처리업무의 중요도(개인정보 영향도)를 산정
- 산정된 개인정보 처리업무 영향도, 침해요인 발생가능성, 법적 준거성을 조합하여 위험도를 평가·합산하는 방법을 적용

■ 개인정보 처리업무별 침해요인 연계 개념도 ■



- 개인정보 처리업무의 중요도, 침해요인의 발생가능성, 법률에 규정된 의무사항 등을 종합적으로 고려하여 도출한 위험도 산정방법

■ 개인정보 침해 위험 위험도 산정예시 ■

$$\text{위험도} = \text{개인정보 영향도} + (\text{침해요인 발생가능성} \times \text{법적 준거성}) \times 2$$

■ 개인정보 영향도(자산 가치) ■

등급	설명	자산가치
1등급	- 그 자체로 개인 식별이 가능하거나 민감한 개인정보 - 관련 법령에 따라 처리가 엄격히 제한된 개인정보 - 유출 시 범죄에 직접적으로 이용 가능한 정보	5
2등급	- 조합되면 명확히 개인의 식별이 가능한 개인정보 - 유출시 법적 책임 부담 가능한 정보	3
3등급	- 개인정보와 결합하여 부가적인 정보 제공 가능 정보 - 제한적인 분야에서 불법적 이용 가능 정보	1

■ 법적 준거성 가중치 부여 ■

구분	법적 준거성	중요도
높음	법적 준수 사항	1.5
낮음	법률 외 요건	1

■ 개인정보 침해요인 발생가능성 ■

구분	발생 가능 정도	중요도
높음	즉각적인 침해 발생 가능성이 있는 경우	3
중간	침해발생 가능성이 존재하지만 즉각적이지는 않는 경우	2
낮음	침해발생 가능성이 희박한 경우	1

■ 위험도 범위 ■

구분	산정식	위험도
최대값	$\text{위험도} = 5 + (3 * 1.5) * 2$	14
최소값	$\text{위험도} = 1 + (1 * 1) * 2$	3

- 침해요인을 기반으로 관련된 개인정보 처리업무 단위로 개인정보 영향도, 침해요인 발생가능성 및 법적 준거성을 조합하여 개인정보 위험도를 산정
- 단, 위험도 산정 방식 및 가중치는 영향평가 기관의 자체 방법론 또는 대상사업의 특성 등을 고려하여 효과적인 방법을 선택하여 결정 가능 (예를 들어 법적준거성 관련 가중치값 조정, 개인정보 영향도 산정 기준으로 "개인정보파일" 단위로 변경, 위험도 산정 공식 변경 등)

■ 개인정보 침해요인 위험도 산정 예시 ■

개인정보 처리업무명	처리 개인정보	개인정보 영향도	질의문 코드	침해요인	발생 가능성	법적 준거성	위험도
회원가입 (수집)	성명, 주민등록번호, 전화번호, 이메일주소, 퇴직정보	5	2.2.1	변경된 부분에 대한 정보가 반영되지 않아 개인정보파일 현황을 적절히 파악하지 못해 보유하고 있는 개인정보의 관리가 어려움	3	1.5	14
회원가입 (보유·이용)	성명, 주민등록번호, 전화번호, 이메일주소, 퇴직정보	5	3.4.1	정보주체가 위탁되는 개인정보 항목 및 위탁 목적 등을 알 수 없게 되어 정보주체의 권리를 제한할 수 있음	3	1.0	11
회원가입 (보유·이용)	성명, 주민등록번호, 전화번호, 이메일주소, 퇴직정보	5	4.3.1	개인정보유출 사고가 발생 시 개인정보를 취득한자가 개인정보를 손쉽게 이용할 수 있음	2	1.0	9
회원가입 (파기)	성명, 주민등록번호, 전화번호, 이메일주소, 퇴직정보	5	3.5.1	관련 법률을 위반하여 징계나 형사 벌, 벌금 등의 처벌을 받을 수 있음	3	1.5	14
민원처리 (수집)	성명, 전화번호, 주소, 이메일주소	3	2.3.2	개인정보 제3자 제공에 대한 기준이 없어 제3자에게 개인정보를 무분별하게 제공하게 될 수 있으며 정보주체의 권리가 침해될 수 있음	3	1.5	12
민원처리 (수집)	성명, 전화번호, 주소, 이메일주소	3	2.2.2	변경된 부분에 대한 정보가 반영되지 않아 개인정보파일 현황을 적절히 파악하지 못해 보유하고 있는 개인정보의 관리가 어려움	3	1.5	12
민원처리 (보유·이용)	성명, 전화번호, 주소, 이메일주소	3	2.2.1	변경된 부분에 대한 정보가 반영되지 않아 개인정보파일 현황을 적절히 파악하지 못해 보유하고 있는 개인정보의 관리가 어려움	3	1.5	12
민원처리 (보유·이용)	성명, 전화번호, 주민등록번호, 이메일주소	5	4.3.1	저장된 정보가 암호화되지 않음에 따라 개인정보유출 사고가 발생 시 개인정보를 취득한자가 개인정보를 손쉽게 이용할 수 있음	2	1.0	9
민원처리 (파기)	성명, 전화번호, 주소, 이메일주소	3	3.5.1	개인정보 미파기에 따른 법률 위반 및 과태료 처분을 받을 수 있음	3	1.5	12
...		...	...	...	...	...	

5. 개선계획 수립

목 표	개인정보 침해 요인별 위험도 분석에 기반하여, 위험요소를 제거하거나 최소화하기 위한 개선방안 및 개선계획을 수립
개 요	도출된 개인정보 침해요소에 대해 기관 내 인력 및 예산 등 자원을 고려하고 유관업무 담당자와의 협의를 거쳐 체계적으로 정비한 개선 계획을 수립함
수행주체	영향평가팀
참고자료	위험도 산정표
산 출 물	개선계획

5.1 개선방안 도출

○ 식별된 침해요인별 위험도를 측정하고 검토한 후, 위험요소를 제거하거나 최소화하기 위한 개선방안 도출

- 개선방안은 위험도의 우선순위에 따라 해당기관이 수용 가능한 수준을 정하여 단기, 중·장기로 구분하고, 수행 시기는 가능한 구체적으로 제시
 - 개선방안의 실질적인 이행을 위하여 담당부서 및 담당자를 명확히 지정
- ※ 법적 필수 사항은 반드시 조치될 수 있도록 개선계획 수립 필요

■ 침해요인별 개선 방안 작성 양식 예시 ■

위험도	개인정보 처리업무명	질의문 코드	침해요인	개선방안	수행시기	담당 부서
14	회원가입 (수집)	2.2.1	변경된 부분에 대한 정보가 반영되지 않아 개인정보파일 현황을 적절히 파악하지 못해 보유하고 있는 개인정보의 관리가 어려움	개인정보파일 변경사항을 파악하여 개인정보파일대장에 빠짐없이 반영	2020.09 (단기)	OO팀
14	회원가입 (수집)	2.2.2	OOO 개인정보파일의 보호위원회 등록이 누락됨에 따라 개인정보 보호법을 위반할 수 있으며, 정보주체의 알 권리를 침해함	OOO 개인정보파일을 내부 승인절차를 거쳐 보호위원회에 등록	2020.09 (단기)	OO팀
14	회원가입 (파기)	3.5.1	회원가입 서류를 관련 법률 등에 명시된 기간을 넘겨 보관하여 처벌을 받을 수 있음	법률근거 및 수집목적에 따라 보유기간으로 산정	2020.09 (단기)	OO팀
...	...	...	...	...		

5.2 개선계획 수립

- 도출된 개선방안을 기반으로 대상기관 내 보안조치현황, 예산, 인력, 사업 일정 등을 고려하여 개선계획 수립
- 도출된 개선계획은 위험평가 결과를 참고하여 위험도가 높은 순서의 개선방안을 먼저 실행하도록 개선계획표 작성
- 개선계획 수립 시 주요 고려사항
 - 담당자가 취약사항을 시정하기 위해 취해야 할 조치사항과 책임사항 제시
 - 위험도(시급성), 개선용이성, 예산, 인력 등을 고려하여 현실적인 일정 수립하되, 법적 의무 사항은 빠른 시일 내에 모두 개선될 수 있도록 계획 수립
 - 예산 확보 등 특별한 사유가 없는 한 개선계획은 시스템 설계·개발 시 반영하여 해당 정보화 사업 기간 내에 조치될 수 있도록 계획 수립(「개인정보 영향평가에 관한 고시」 제9조의2 및 제9조의3)
 - 대상기관에서 개선계획 이행 시 즉시 활용할 수 있도록 구체적이고 효과적인 방안 제시
 - 침해요인 별 유사 항목은 취합하여 한 개의 개선 과제로 제시 가능
 - 침해요인 도출 단계와의 연계성 및 추적성을 확보할 수 있도록 개선과제와 관련된 평가항목 번호(질의문 코드) 표기

■ 개선 계획표 예시 ■

순번	개선과제명	개선내용	담당부서	수행 시기
1	개인정보보호 교육 강화	- 개인정보보호 교육계획 수립(2.1.2) - 개인정보취급자에 대한 교육 수행(2.1.2)	고객보호팀	사업종료전 (2020.06)
2	개인정보 수집·저장 시 보호조치 강화	- 회원 가입 시 입력받는 개인정보 수집항목 최소화(3.1.2) - 회원정보 DB 저장시 암호화 등의 설계 변경(4.3.1)	사업주관 부서	사업종료전 (2020.06)
3	개인정보취급자 PC 보안강화	- 개인정보취급자 단말기에 키보드 해킹방지 솔루션 도입(4.8.2)	사업주관 부서	2차 사업 (2021.06)
	...			

○ 도출된 개선과제에 대하여 실질적인 개선이 가능하도록 상세 개선방안 제시

- 침해요인 방지를 위한 효과적이고 구체적인 개선방안을 작성하여야 하며, 대상기관에서 과제 이행에 도움이 될 수 있도록 관련 사례가 있는 경우 함께 제시
- 평가기관의 전문성과 경험, 노하우를 활용하여 대상기관 및 시스템 관점에서 최적의 개선방안을 상세하게 제시

■ 상세 개선방안 작성 양식 예시 ■

개선과제명	1. 홈페이지 회원 비밀번호 일방향 암호화	순번	1																																		
관련 평가항목	4.3.1	법적 요건	필수 사항																																		
과제 상세 내용	○ 일방향 암호화 대상 정보 : 홈페이지 회원 비밀번호, 관리자 비밀번호																																				
	○ 일방향 암호화 알고리즘 : SHA-256 이상 적용 필요																																				
	[보안강도에 따른 일방향(단순해쉬/전자서명용 해쉬함수) 암호 분류]																																				
	<table><tr><th>보안강도</th><th>NIST(미국)</th><th>CRYPTREC(일본)</th><th>ECRYPT(유럽)</th><th>국내</th><th>안전성 유지기간(년도)</th></tr><tr><td>80비트 이상</td><td>SHA-1 SHA-224/256/384/512</td><td>SHA-1† SHA-256/384/512 RIPEMD-160</td><td>SHA-1 SHA-256/384/512 RIPEMD-160 Whirlpool</td><td>SHA-1 HAS-160 SHA-256/384/512</td><td>2010년까지</td></tr><tr><td>112비트 이상</td><td>SHA-224/256/384/512</td><td>SHA-256/384/512</td><td>SHA-256/384/512 Whirlpool</td><td>SHA-256/384/512</td><td>2011년부터 2030년까지 (최대 20년)</td></tr><tr><td>128비트 이상</td><td>SHA-256/384/512</td><td>SHA-256/384/512</td><td>SHA-256/384/512 Whirlpool</td><td>SHA-256/384/512</td><td rowspan="3">2030년 이후 (최대 30년)</td></tr><tr><td>192비트 이상</td><td>SHA-384/512</td><td>SHA-384/512</td><td>SHA-384/512 Whirlpool</td><td>SHA-384/512</td></tr><tr><td>256비트 이상</td><td>SHA-512</td><td>SHA-512</td><td>SHA-512 Whirlpool</td><td>SHA-512</td></tr></table>			보안강도	NIST(미국)	CRYPTREC(일본)	ECRYPT(유럽)	국내	안전성 유지기간(년도)	80비트 이상	SHA-1 SHA-224/256/384/512	SHA-1† SHA-256/384/512 RIPEMD-160	SHA-1 SHA-256/384/512 RIPEMD-160 Whirlpool	SHA-1 HAS-160 SHA-256/384/512	2010년까지	112비트 이상	SHA-224/256/384/512	SHA-256/384/512	SHA-256/384/512 Whirlpool	SHA-256/384/512	2011년부터 2030년까지 (최대 20년)	128비트 이상	SHA-256/384/512	SHA-256/384/512	SHA-256/384/512 Whirlpool	SHA-256/384/512	2030년 이후 (최대 30년)	192비트 이상	SHA-384/512	SHA-384/512	SHA-384/512 Whirlpool	SHA-384/512	256비트 이상	SHA-512	SHA-512	SHA-512 Whirlpool	SHA-512
	보안강도	NIST(미국)	CRYPTREC(일본)	ECRYPT(유럽)	국내	안전성 유지기간(년도)																															
80비트 이상	SHA-1 SHA-224/256/384/512	SHA-1† SHA-256/384/512 RIPEMD-160	SHA-1 SHA-256/384/512 RIPEMD-160 Whirlpool	SHA-1 HAS-160 SHA-256/384/512	2010년까지																																
112비트 이상	SHA-224/256/384/512	SHA-256/384/512	SHA-256/384/512 Whirlpool	SHA-256/384/512	2011년부터 2030년까지 (최대 20년)																																
128비트 이상	SHA-256/384/512	SHA-256/384/512	SHA-256/384/512 Whirlpool	SHA-256/384/512	2030년 이후 (최대 30년)																																
192비트 이상	SHA-384/512	SHA-384/512	SHA-384/512 Whirlpool	SHA-384/512																																	
256비트 이상	SHA-512	SHA-512	SHA-512 Whirlpool	SHA-512																																	
○ 비밀번호 일방향 암호화 적용 시 고려 사항 (Salt값 적용 등)																																					
○ 패스워드 일방향 암호화 적용 방법 (시스템 신규 구축 시) ➔ 일방향 암호화 강도 증가를 위하여, 비밀번호에 Salt값을 적용 (단, Salt값은 자체적으로 정의 → 비밀 유지 필요) ※ 적용 예시 : Salt값을 "ID+@"으로 정의한 경우 사용자 ID : test123 / 비밀번호 : password1234 ➔ 일방향 암호화["test123@password1234"] ➔ 92aed87de83cdae8dafd..... ➔ 비밀번호 일방향 암호화 적용 후 로그인 프로세스 사용자 ID/ 비밀번호 입력 로그인 페이지 입력 ID 입력 비밀번호 Salt값+비밀번호 해쉬값 비밀번호 ID DB내 ID DB내 해쉬값 ※ 일방향 암호화 적용 비교결과 같으면 인증성공 처리 비교 ➔ 적용 절차 1) 일방향 암호화 모듈 작성 (공개용 또는 상용 암호화 라이브러리 활용) 2) 비밀번호 최초 설정 및 비밀번호 변경 시 일방향 암호화해서 DB에 저장하도록 프로그램 수정 3) 로그인 시 사용자가 입력한 비밀번호를 동일한 메커니즘으로 일방향 암호화해 DB와 비교하도록 프로그램 수정 4) 비밀번호 분실 시 기존 비밀번호 초기화 및 사용자 통지 절차 수립 및 관련 프로그램 수정																																					
담당부서 (수행 주체)	OO팀	수행 시기	2018.06																																		
관련 법률	- 개인정보 보호법 제29조(안전조치의무) - 개인정보의 안전성 확보조치 기준 고시 제7조(개인정보의 암호화)																																				

6. 영향평가서 작성

목 표	영향평가의 모든 과정 및 산출물을 정리하여 영향평가서 작성
개 요	영향평가 추진경과 및 중간산출물 등의 내용을 정리하고 도출된 위험요소 및 개선계획 등 최종산출물들을 모두 취합하여 영향평가서를 작성하고, 대상기관은 보고서 품질을 검토함
수행주체	영향평가팀, 대상기관
참고자료	평가팀구성표, 운영계획서, 사업개요서, 평가계획서, 업무흐름도, 개인정보 흐름표, 개인정보 흐름도, 시스템구조도, 침해요인도출, 위험 평가표, 개선계획표, 영향평가항목 점검표
산 출 물	영향평가서, 품질점검 결과표

- 영향평가서는 사전 준비단계에서부터 위험관리 단계까지 모든 절차, 내용, 결과 등을 취합·정리한 문서
- 잔존 위험이나 이해관계자 간의 의견충돌이 있는 경우에는 의사결정권자(CEO, CPO 등)를 토론에 참여시켜 개인정보보호 목표수준에 대한 합의 도출
- 영향평가팀은 영향평가서를 최종적으로 검토 또는 승인할 수 있는 조직 내 최고 의사결정권자(기관장)에게 보고
- 대상기관내 다수의 개인정보처리시스템에 대하여 동시에 영향평가를 수행한 경우에는 개인정보처리시스템 단위로 영향평가서를 분리하여 작성
 - ※ 단, “대상기관 개인정보보호 관리체계” 평가영역은 한 번만 작성 가능

■ 영향평가서 작성 ■

목차	주요 내용
표지	▶ 대상 사업명, 날짜, 사업 수행 부서 등 기재
영향평가서 개요	▶ 「개인정보 영향평가에 관한 고시」 별지 7호 서식에 따른 개인정보 영향평가서 개요 작성
요약	▶ 영향평가에 대한 간략한 요약, 획득한 결론과 개선 사항들을 요약된 형태로 기술
목차	▶ 영향평가서의 주요 장과 절, 그리고 이들이 수록된 페이지 번호를 명시
I. 추진 개요	
1. 사업(시스템)명	▶ 대상사업(시스템)명 기재
2. 추진 경과	▶ 평가팀 구성 등 영향평가 시작~종료시점까지 주요 경과 기술
3. 개인정보파일 개요	▶ 영향평가 대상시스템에서의 분석된 개인정보파일에 대한 내용 기술
II. 개인정보 흐름분석	
1. 필요성 검토 결과	▶ 필요성 검토 결과 기재
2. 개인정보 처리업무표 및 업무흐름도	▶ 전체 업무 중 개인정보와 관련한 업무흐름
3. 개인정보 흐름표	▶ 개인정보 흐름표 제시 및 설명
4. 개인정보 흐름도	▶ 개인정보 흐름도 제시 및 설명
5. 시스템 구조도	▶ 대상사업의 시스템 구조도 제시
III. 영향평가 결과	
1. 대상기관 개인정보보호 관리체계	▶ 각 분야별 조치 현황 및 침해 요인 기술
2. 대상시스템의 개인정보보호 관리체계	
3. 개인정보 처리단계별 보호조치	
4. 대상시스템의 기술적 보호조치	
5. 특정 IT기술 활용시 개인정보 보호조치	
IV. 위험평가	
1. 위험평가 개요	▶ 위험평가 개요 기술
2. 위험평가 결과	▶ 위험평가 결과 기술
3. 개선방안 도출	▶ 도출된 개선사항 정리
4. 개선계획 수립	▶ 도출된 개선사항의 이행계획 수립
V. 총평	

- 영향평가서는 「개인정보 영향평가에 관한 고시」 별지 제7호 서식에 따라 '개인정보 영향평가서 개요'를 작성하여 영향평가서에 포함

※ 개인정보 영향평가서 개요 작성방법

개인정보 영향평가서 개요										
공공기관명		- 영향평가 대상 공공기관명								
평가 대상 시스템 개요	시스템명	- 영향평가 대상 개인정보처리시스템명					추진 일정	- 대상 시스템의 사업기간 (YYYY.MM.DD ~ YYYY.MM.DD)		
	추진개요 및 목적	- 영향평가 대상 시스템 구축·변경 사업의 추진 개요 및 목적 (핵심적인 사항 중심으로 간략히 작성)								
	추진 성격	대상여부	- 법 시행령 제35조의 각 요건 중 어디에 해당하는지 기록 ① 5만 이상 민감정보·고유식별정보 처리 ② 50만 이상 개인정보파일 연계 ③ 100만 이상 개인정보파일 처리 ④ 기존에 영향평가를 받은 후 변경				추진 예산	- 대상 시스템의 사업비용 (단위:천원)		
		추진주체	- 사업 추진 기관명							
		추진근거	- 사업 추진의 근거가 되는 법령, 계획 등				비고	- 특이사항 기록 ① 신규 구축·개발 ② 변경(고도화 등) ③ 표준배포시스템 ④ 기타 특이사항		
주요 내용		- 사업의 주요 내용								
개인 정보 파일 개요	개인정보 수집목적		- 개인정보 수집목적							
	평가대상 파일	파일명			정보주체수		파일 및 범위 설명			
		- 영향평가 대상 개인정보파일명 ※ 개인정보파일 수가 많을 경우 행을 삽입하여 추가 작성			○○명		- 개인정보파일에 대한 설명 기술			
주요 개인정보 수집현황		○ 총 ()개 항목 : - 필수 수집 : - 선택 수집 :								
영향 평가 항목	주요 평가항목 변경 내역	주요내용								
		지표추가 항목		- 수행안내서 지표기준으로 추가된 지표 개수 및 지표번호, 지표명 기술						
		지표삭제 항목		- 해당사항 없음 등의 사유로 평가에서 제외된 지표 개수 및 내용 기술						
평가 결과 및 개선 계획	평가 결과 및 개선 사항	주요 내용	○ 침해요인 및 개선사항 관련 주요 내용 기술							
		침해요인 도출건수	개선대책 도출건수		개선계획 수립건수		조치완료 건수		조치예정 건수	
		건	건		건		건		건	
	주요개선 계획 및 일정		○ 주요 개선계획 및 일정 기술(개선계획 수가 많을 경우 행을 삽입하여 추가 작성)							
	평가기관		평가기관명	평가기간	YYYY.MM.DD ~ YYYY.MM.DD		평가예산		○○천원 (VAT포함)	

- 대상기관은 영향평가가 충실히 수행되었는지 여부에 대해 품질평가 체크리스트를 바탕으로 점검 후 미흡한 사항이 있는 경우 보완 요청

※ 개인정보 영향평가서 품질검토 체크리스트(예시)

구분	체크리스트	확인 자료
영향평가서 필수사항	1. 영향평가서는 법적 필수사항을 모두 포함하여 작성되었는가? (「개인정보 보호법」 시행령 제38조 제2항) ①개인정보파일 운용과 관련된 사업의 개요 및 개인정보파일 운용의 목적 ②영향평가 대상 개인정보파일의 개요 ③평가기준에 따른 개인정보 침해의 위험요인에 대한 분석·평가 및 개선이 필요한 사항 ④영향평가 수행 인력 및 비용	영향평가서
투입인력의 자격요건	2. 영향평가 수행 인력은 필요한 자격요건을 갖추었는가? [투입인력 자격요건] ※아래 3가지 요건을 모두 만족해야 함 - 자격증 : SIS(정보보안기사), 감리원, 기술사, CISSP, CISA, CPPG, 박사 - 경력 : 개인정보 영향평가 관련 분야 1년 이상 경력 - 전문교육 : 전문교육 이수 후 전문인력 인증서 획득 [확인 방법] - 개인정보보호 포털 → 사업자 → 개인정보 영향평가 → 영향평가 수행 인력 조회 (투입인력의 인증번호 및 이름으로 조회)	투입인력 인증번호
개인정보 흐름분석의 식별성	3. 평가대상 개인정보파일 및 관련 업무에 대해 총괄 개인정보흐름도 및 업무별 개인정보흐름도가 충실히 작성되었는가? [총괄 개인정보흐름도] - 전체 개인정보 흐름을 한눈에 알아볼 수 있도록 작성 [업무별 개인정보흐름도] - 개인정보 현황분석 단계에서 분류한 개인정보 처리업무 별로 상세한 개인정보 흐름이 파악될 수 있도록 작성 - 평가대상 개인정보파일 및 개인정보 처리업무를 빠짐없이 포함하여 작성 4. 개인정보흐름도는 개인정보 흐름이 명확히 식별될 수 있도록 구체적으로 작성되었는가? - 식별성을 높일 수 있도록 도형, 색상, 기호 등을 활용 - 우려사항이 있는 경우 흐름도 상에 발생위치를 표시하고 관련 평가항목 번호(지표번호)를 명시하여 평가단계별 추적성 확보 - 개인정보 수집 방법, 외부 제공 및 연계 방식, 흐름상에 전송되는 정보를 명확히 파악할 수 있도록 작성 등	개인정보 흐름도
평가항목의 적합성	5. 평가항목(평가지표)은 최신 법령·고시 사항이 반영되어 있는가? - 개인정보 보호법 및 시행령, 시행규칙 - 개인정보의 안전성 확보조치 기준, 표준 개인정보 보호지침 등 관련 고시 ※ 법령, 고시 개정사항은 평가항목에 즉시 반영되어야 하며, 유예기간 등 시행이 확정된 사항에 대해서는 선제적 반영 필요	평가항목 (평가지표)

	6. 평가항목(평가지표)은 대상 기관 및 시스템의 특성, 최신 보안 위협 등을 반영하여 최적화 되었는가? (해당하는 경우에 한함) - 대상 기관이 특별히 적용받는 법령, 고시가 있는 경우, 관련 사항을 평가항목에 반영(의료법, 교육법 등) - 기존 평가항목에 없는 특정 IT기술을 사용하는 경우, 필요한 사항을 평가항목에 추가	
평가항목 점검의 충실성	7. 평가결과에는 오류가 없으며 평가항목별 증적이 객관적이고 상세하게 제시되었는가? - 평가증적은 제3자가 보더라도 평가결과를 납득할 수 있도록 구체적으로 제시되어야 함(화면 캡처, 설계문서 사진 등) - 법령, 고시 등 법적 요건에 대한 해석 및 점검에 오류사항이 없어야 함 - 개인정보 현황 및 흐름도, 대상 기관 및 시스템의 현황과 비교하여 점검 결과에 오류사항이 없어야 함 [평가오류 사례] ①개인정보 흐름도에는 개인정보 수집 시 동의 절차가 누락된 것으로 되어 있으나, 평가항목 점검 결과에는 동의를 적절하게 받고 있는 것으로 평가 ②개인정보 처리업무표에는 민감정보를 수집하는 것으로 표기되어 있으나, 민감정보 수집 관련 평가항목에서는 해당사항 없음으로 표기 8. 평가항목 점검 결과는 개인정보 흐름분석 단계와 연계성이 확보되었는가? - 개인정보 흐름분석 단계에서 식별된 개인정보 수집, 저장, 이용, 제공 및 파기 경로, 외부 위탁 관련 사항이 빠짐없이 점검되어야 함 [평가미흡 사례] ①개인정보 흐름도에서는 개인정보 수집경로가 온라인(홈페이지) 및 오프라인(민원센터)이 존재하는 것으로 기록되어 있으나, 개인정보 수집 적정성 관련 평가항목 점검시 온라인 영역에 대해서만 점검하고 오프라인 영역은 점검하지 않은 경우 ②개인정보 흐름도에서는 개인정보를 제공받는 자가 3개 외부기관으로 식별되어 있으나, 개인정보 제3자 제공 관련 평가항목 점검 시 1개 외부기관에 대해서만 점검 결과가 기록된 경우 ※관련 평가표 사례는 아래 [참고1]과 [참고2] 참고 9. 평가항목 별로 반드시 점검해야 할 세부점검 사항이 빠짐없이 점검되었는가? - 평가항목 별로 반드시 점검되어야 할 세부 점검사항에 대해서는 빠짐 없이 점검을 수행하고 점검표에 평가결과를 기록해야 함 [평가미흡 사례] ①내부관리계획의 적절성을 점검하면서 내부관리계획에 반드시 포함되어야 할 항목(유형3 기준으로 15개 항목)이 모두 포함되어 있는지 여부를 확인하지 않은 경우 ②개인정보 저장시 암호화 항목을 점검하면서 암호화 저장여부만 점검하고 안전한 암호알고리즘 사용여부를 점검하지 않은 경우 ※관련 평가표 사례는 아래 [참고3] 참고	평가항목 점검표

	10. 기술적 보호조치 관련 영역 점검 시 응용시스템 뿐만 아니라, 평가 범위에 포함된 서버, DBMS 등 인프라 영역에 대한 점검도 수행되었는가? (서버, DBMS 등 인프라 영역이 영향평가 범위에 포함된 경우에 한함) - 영향평가 범위에 서버, DBMS 등 인프라 영역이 포함되어 있는지 확인 후, 평가범위에 포함되어 있다면 평가항목별 점검 시 응용시스템 외에 서버, DBMS 영역에 대한 점검도 함께 수행 필요 ※계정관리(4.1.1), 인증관리(4.1.2, 4.1.4, 4.1.5, 4.1.6, 4.1.7), 권한관리(4.1.8, 4.1.9, 4.1.10), 접근통제(4.2.1, 4.2.2, 4.2.3), 인터넷 홈페이지 보호조치(4.2.5), 저장 시 암호화(4.3.1, 4.3.2), 접속기록 보관(4.4.1), 백신 설치 및 운영(4.5.1), 보안업데이트 적용(4.5.2) 등 ※단, 영향평가 사업의 범위, 시스템 구성, 운영형태에 따라 상이 - 표준배포시스템의 경우 중앙에서 수행한 평가지표에 대해서는 제외 가능하지만 서버, DBMS 등을 지자체에서 직접 관리하고 있다면 해당 영역에 대해서는 평가 수행 필요 [평가누락 사례] ①평가 범위에 개인정보처리시스템이 운용되는 서버가 포함되어 있으나, 보안업데이트 영역 점검 시 개인정보취급자 PC에 대한 점검만 수행하고 서버OS, 웹서버(Apache, OpenSSL) 등에 대한 점검은 수행되지 않음 ②접속기록 영역을 점검하면서 응용프로그램을 통한 접속 시 접속기록을 남기는지에 대해서는 점검을 수행하였으나, DBA 등 운영자가 DB에 직접 접속하는 경우에도 접속기록이 남는지 여부에 대해서는 점검하지 않음	
위험분석의 합리성	11. 침해요인의 내용 및 위험도의 크기는 실질적인 위험을 대변할 수 있도록 합리적으로 도출되었는가? - 침해요인의 내용은 대상 기관 및 시스템의 관점에서 어떤 문제가 있는지 명확히 알 수 있도록 구체적이고 알기 쉽게 표현되어야 함 - 법규 위반 관련 침해요인은 어떤 조항을 위반한 것이며 그로 인해 어떤 처벌과 문제가 발생할 수 있는지를 알 수 있도록 기술되어야 함 - 위험분석 절차는 논리적이고 합리적인 방법론으로 수행되어야 하며, 위험도의 크기는 대상 기관 및 시스템의 관점에서 실질적인 위험의 크기를 대변할 수 있어야 함	위험분석 결과
개선 계획의 활용성	12. 침해요인 별로 개선방안이 빠짐없이 제시되었으며, 개선계획은 즉시 활용가능 하도록 구체적이고 실질적인 내용으로 수립되었는가? - 도출된 모든 침해요인을 해결할 수 있도록 개선 방안이 빠짐없이 제시되어야 함 (단, 개선과제는 유사한 과제를 묶어서 제시 가능) - 각 개선방안은 해당 침해요인을 효과적으로 해결할 수 있는 최적의 방안이 제시되어야 함 - 평가기관의 일방적 제안은 지양하고, 개선방안 및 개선계획 수립시 실제 이행을 담당할 조직 및 담당자와 충분한 협의를 수행해야 함 - 개선방안 및 개선계획은 대상기관이 즉시 활용하여 이행할 수 있도록 전문적이고 상세하게 제시되어야 함 · 대상 기관 및 시스템의 특성을 반영(단순 Copy & Paste 지양) · 이행 관점에서 실질적인 도움이 될 수 있도록 유사 사례 제시 · 평가기관의 전문성을 발휘하여 How-to 관점에서 상세 방안 제시	개선계획, 상세 개선방안

[참고1] 평가항목 점검표 사례(흐름분석 단계와 연계성)

→ 개인정보 흐름분석 단계에서 식별된 4개 개인정보파일과 6개 개인정보 수집 관련 업무에 대해 빠짐없이 점검

세부분야	개인정보 수집의 적합성				
질의문 코드	질의문	이행	부분이행	미이행	해당없음
3.1.1	○ 개인정보를 수집하는 경우 법률에 근거하거나 정보주체의 동의를 받도록 계획하고 있습니까?		○		
평가근거 및 의견	○ a1업무에서 처리하는 개인정보는 ○○의 목적으로 대부분이 고등교육법, 교육기본법, 교원자격검정령 등에 근거하여 수집되어 처리됨				
	○ 그러나, b1업무의 채용이전에 응시원서를 통해 개인정보를 수집할 경우, 정보주체의 동의를 받고 수집하여야 하나 구체적인 동의 안내 없이 수집하고 있으며, 특히, 주민등록번호는 법률근거가 없이 수집되고 있음				
	○ 아래 표는 평가업무별 개인정보 수집에 따른 수집 근거는 다음과 같음				
	개인정보 파일	평가업무명	수집 근거	적절성 여부	비고
	A파일	- a1 업무 - a2 업무 - a3 업무	교육기본법 제 16조 고등교육법 시행령 제4조 고등교육법 시행령 제73조	○	-
	B파일	- b1 업무	정보주체의 동의	X	주민등록번호 법적 수집근거 부재
C파일	- c1 업무	영유아보육법 제51조의2 영유아보육법 시행령 제26조의2 영유아보육법 시행령 제26조의3	○	-	
D파일	- d1 업무	노인복지법 제39조의3 노인복지법 시행령 제26조	○	-	
증적 자료	○○기관 개인정보 수집 증적				
	a1업무, a2업무, a3업무 수집 신청서 양식		b1업무 수집 신청서 양식		
	c1업무 수집 신청서 양식		d1업무 수집 신청서 양식		
관련 법률 및 문서	○ 개인정보보호법 제15조(개인정보의 수집·이용) ○ 표준개인정보보호지침 제6조(개인정보의 수집·이용)				

[참고2] 평가항목 점검표 사례(흐름분석 단계와 연계성)

→ 개인정보 흐름분석 단계에서 식별된 3개 수탁업체에 대해 위탁계약이 빠짐없이 체결되었는지 및 위탁계약서 내에 법적 필수 항목이 모두 포함되었는지 확인

세부분야	위탁 계약																				
질의문 코드	질의문	이행	부분이행	미이행	해당없음																
3.4.2	○ 개인정보 처리에 관한 업무 위탁 시 개인정보 관리에 관한 책임사항 등이 포함된 문서를 작성하도록 계획하고 있습니까?		○																		
평가근거 및 의견	○ 000시스템은 “X업체”에 시스템 유지보수 운영위탁을 위한 개인정보 위탁계약서를 작성하여 문서화하고 있으며, a1업무 운영 위탁을 위한 Y업체 개인정보처리 위탁계약서를 작성하고 있음																				
	○ 개인정보처리 위탁계약서 내에서는 개인정보보호법 제26조(업무위탁에 따른 개인정보의 처리 제한)에 따라 포함되어야 할 7가지 항목(위탁업무 수행 목적 외 개인정보의 처리금지에 관한 사항, 개인정보의 기술적 관리적 보호조치에 관한사항, 위탁업무의 목적 및 범위, 재위탁 제한에 관한 사항, 개인정보 접근제한 등 안전성확보조치에 관한 사항, 관리감독에 관한 사항, 손해배상 등 책임에 관한 사항)을 문서화하고 있음																				
	○ 그러나 b1업무를 수행하기 위한 ARS 업무 위탁을 진행하는 Z업체와는 개인정보처리 위탁계약서를 작성하지 않음																				
	○ 개인정보 위탁에 따른 수탁사 별 계약 현황은 아래와 같음																				
	<table><tr><th>수탁사 명</th><th>위탁내용</th><th>위탁계약서</th><th>필수항목 포함여부</th></tr><tr><td>X업체</td><td>시스템 유지보수 운영위탁</td><td>○</td><td>7가지 항목 포함</td></tr><tr><td>Y업체</td><td>a1업무 운영위탁</td><td>○</td><td>7가지 항목 포함</td></tr><tr><td>Z업체</td><td>b1업무에서의 ARS 위탁</td><td>X</td><td>미포함</td></tr></table>				수탁사 명	위탁내용	위탁계약서	필수항목 포함여부	X업체	시스템 유지보수 운영위탁	○	7가지 항목 포함	Y업체	a1업무 운영위탁	○	7가지 항목 포함	Z업체	b1업무에서의 ARS 위탁	X	미포함	
수탁사 명	위탁내용	위탁계약서	필수항목 포함여부																		
X업체	시스템 유지보수 운영위탁	○	7가지 항목 포함																		
Y업체	a1업무 운영위탁	○	7가지 항목 포함																		
Z업체	b1업무에서의 ARS 위탁	X	미포함																		
증적 자료	<table><tr><th colspan="2">개인정보 처리업무 위탁계약서</th></tr><tr><td> X업체 위탁계약서 </td><td> Y업체 위탁계약서 </td></tr></table>					개인정보 처리업무 위탁계약서		X업체 위탁계약서	Y업체 위탁계약서												
	개인정보 처리업무 위탁계약서																				
X업체 위탁계약서	Y업체 위탁계약서																				
관련 법률 및 문서	○ 개인정보보호법 제26조(업무위탁에 따른 개인정보의 처리제한) ○ 개인정보보호법 시행령 제28조(개인정보의 처리 업무 위탁 시 조치)																				

[참고3] 평가항목 점검표 사례(세부 점검사항 점검)

→ 개인정보보호법 및 시행령에 따라 개인정보 처리방침에 반드시 포함되어야 할 11가지 사항이 모두 포함되어있는지 확인

세부분야	개인정보 처리방침				
질의문 코드	질의문	이행	부분이행	미이행	해당없음
2.3.2	○ 개인정보 처리방침은 법령 등에서 규정된 내용을 모두 반영하도록 계획하고 있습니까?		○		
평가근거 및 의견	○ ○○기관 홈페이지에서 안내하고 있는 개인정보 처리방침은 개인정보보호법 제30조 등에서 규정된 내용을 대부분 반영하여 수립되어 있으나, “인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치, 운영 및 그 거부에 관한 사항”이 누락됨				
	번호	개인정보 처리방침 기재사항			반영 여부
	1	개인정보의 처리 목적			○
	2	개인정보의 처리 및 보유 기간			○
	3	개인정보의 제3자 제공에 관한 사항			○
	4	개인정보처리의 위탁에 관한 사항			○
	5	정보주체의 권리,의무 및 그 행사방법에 관한 사항			○
	6	처리하는 개인정보의 항목			○
	7	개인정보의 파기에 관한 사항			○
	8	개인정보 보호책임자 성명 또는 개인정보보호 업무 및 관련 고충사항을 처리하는 부서의 명칭과 전화번호 등 연락처			○
	9	개인정보 처리방침의 변경에 관한 사항			○
	10	시행령 제30조제1항에 따른 개인정보의 안전성 확보조치에 관한 사항			○
	11	인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치, 운영 및 그 거부에 관한 사항			X (쿠키,IP주소를 수집하고 있으나, 처리방침 미공개)
증적 자료	○○기관 개인정보 처리방침 개인정보의 처리 목적, 보유기간, 처리하는 개인정보의 항목 개인정보보호법 제32조(아) 단락을 준거하는 개인정보처리자의 처리목적, 보유기간 및 처리하는 개인정보의 항목은 아래와 같습니다. ● 개인정보처리 내역 : 다음표시 ● 개인정보처리 현황은 아래의 방법으로 확인하실 수 있습니다. ● 개인정보보호 종합지원 포털(www.privacy.go.kr) > 개인정보침해 > 개인정보침해 신고 > 개인정보침해 신고 접수 개인정보의 제3자 제공 ● 정보주체로부터 별도의 동의를 받는 경우 ● 법령에 특별한 규정이 있는 경우 ● 정보주체 또는 법정대리인이 의사표시를 할 수 있는 상태에 있거나 주소불명 등으로 사전 동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우 ● 통계작성 및 학술연구 등의 목적을 위하여 필요한 경우로서 특정 개인을 알아볼 수 없는 형태로 개인정보를 제공하는 경우 ● 개인정보 처리의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한 다른 법령에서 말하는 소관 업무를 수행할 수 있는 경우로서 개인정보를 보유취득한 후의 필요로 인하여 수집하거나 수집 제3자에게 제공하지 아니한				

- 영향평가 결과에 따른 개선사항이 사업추진 과정에서 계획대로 반영되어 개선되는지 이행점검을 통해 지속적으로 관리 필요
 - 완료된 영향평가서는 해당 개인정보파일을 구축·운영하기 전에 보호위원회로 제출* (「개인정보 보호법」 시행령 제38조제2항)
 - 단, 기존에 운용 중이던 개인정보파일인 경우 영향평가 사업 완료 후 2개월 이내에 보호위원회에 제출(「개인정보 영향평가에 관한 고시」 제12조)
- * 개인정보보호 종합지원시스템(<https://intra.privacy.go.kr>)에 등록

제3절 이행단계

1. 이행점검

목 표	개인정보 침해요인에 대한 조치내역을 확인
개 요	개인정보 침해요인별 조치가 필요한 사안에 대하여 그에 대한 조치결과를 확인·점검하는 과정
수행주체	사업주관부서, 평가기관 및 감리사업자
참고자료	영향평가서
산 출 물	조치내역서, 개인정보 영향평가 개선사항 이행확인서

1.1 개선사항 반영여부 점검 (개인정보파일 구축·운용 前)

- 분석·설계 단계에서 수행한 영향평가 개선계획의 반영여부를 개인정보파일 및 개인정보처리시스템 구축·운영 전에 확인
 - 대상기관은 정보시스템 분석·설계 단계에서 수행한 영향평가 결과 및 개선계획에 따라 필요한 사항을 반영
 - 감리 대상 정보화사업의 경우에는 영향평가 개선계획의 반영여부를 정보시스템 감리 시 확인
 - 감리를 수행하지 않는 경우에는 정보시스템 테스트 단계에서 자체적으로 영향평가 개선계획의 반영 여부 확인

1.2 개선사항 이행 확인

- 영향평가서를 제출받은 공공기관의 장은 개선사항으로 지적된 부분에 대한 이행 현황을 영향평가서를 제출받은 날로부터 1년 이내에 보호위원회에 제출 (「개인정보 영향평가에 관한 고시」 제14조)
 - 영향평가 시 도출된 개선계획이 예정대로 수행이 되고 있는 지 여부에 대해 점검 후 “개인정보 영향평가 개선사항 이행확인서”를 작성하여 보호위원회에 제출*
 - * 개인정보보호 종합지원시스템(<https://intra.privacy.go.kr>)의 해당 영향평가 보고서 내 첨부
 - 개선계획 이행점검 결과는 내부 보고 절차를 거쳐 보호위원회에 제출하도록 하며, 이행점검 결과 미흡한 부분은 원인 등을 분석하여 계획대로 이행될 수 있도록 조치방안 마련
 - 단, 기존 영향평가 수행기간 내에 모든 개선사항이 조치 완료되어 보호위원회에 제출한 영향평가서에 개선과제가 없는 경우에는 ‘개인정보 영향평가 개선사항 이행확인서’를 제출할 필요 없음
- 개선사항에 대한 이행현황을 보호위원회에 제출할 때는 아래 양식을 활용

■ 이행확인서 양식 ■

■ 개인정보 영향평가에 관한 고시 [별지 제8호서식]

개인정보 영향평가 개선사항 이행확인서					
평가영역	개선과제명	개선요구내용	이행계획(또는 결과)	완료일 (또는 예정일)	담당자 확인

